Improving Account Security for Victims of Account Compromise through Client-Side Access Logging

Carolina Ortega Pérez, Paul Gerhart,
Alaa Daffalla, Thomas Ristenpart

RWC 2026

Cornell University
TU WIEN
PRIVACY ENHANCING TECHNOLOGIES
UNIVERSITY OF TORONTO

Accounts

Accounts

How do users detect if their account has been compromised?

Account security in intimate partner violence

Account security in intimate partner violence

- Works to help **survivors of intimate partner violence** (IPV) experiencing tech abuse

Account security in intimate partner violence

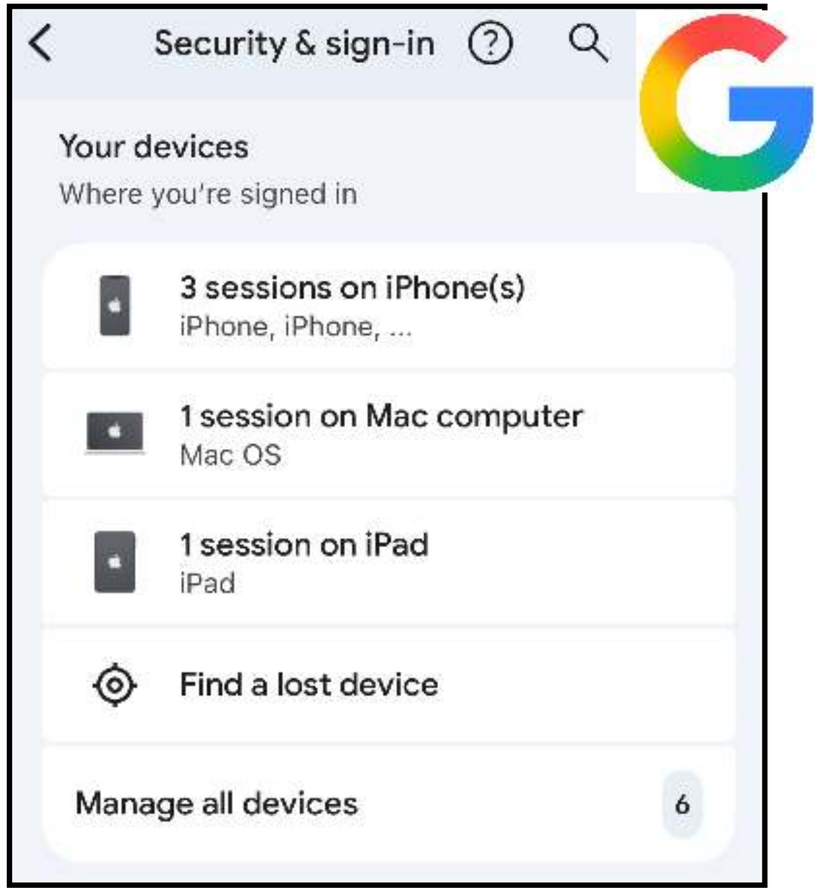
- Works to help **survivors of intimate partner violence** (IPV) experiencing tech abuse
- **Account compromise** frequent problem:

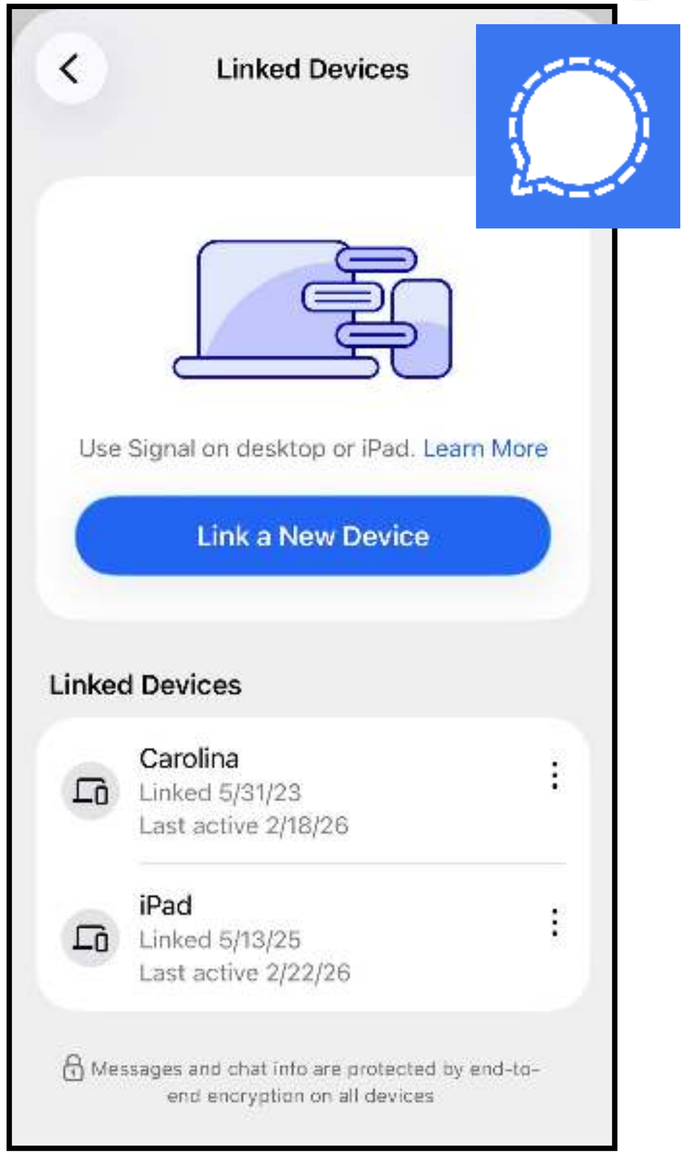
Account security in intimate partner violence

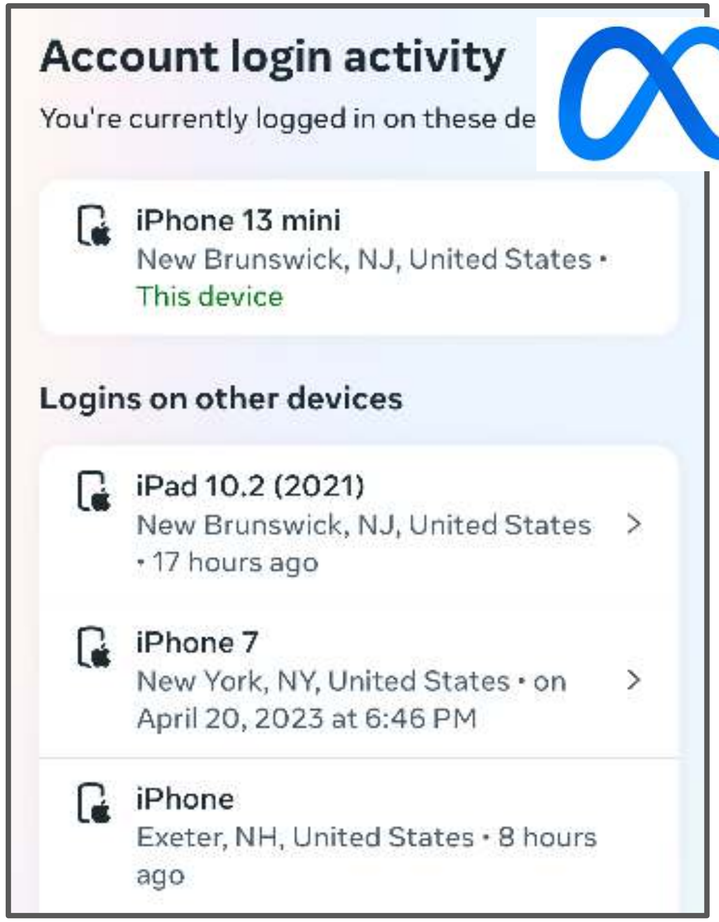
- Works to help **survivors of intimate partner violence** (IPV) experiencing tech abuse
- **Account compromise** frequent problem:
  - Abusers can often bypass authentication
  - May be unsafe to remove abuser
  - Survivors want to know whether access occurred
- We help survivors check **account security interfaces** (ASIs)

CETA
CLINIC TO END TECH ABUSE

Account security in intimate partner violence

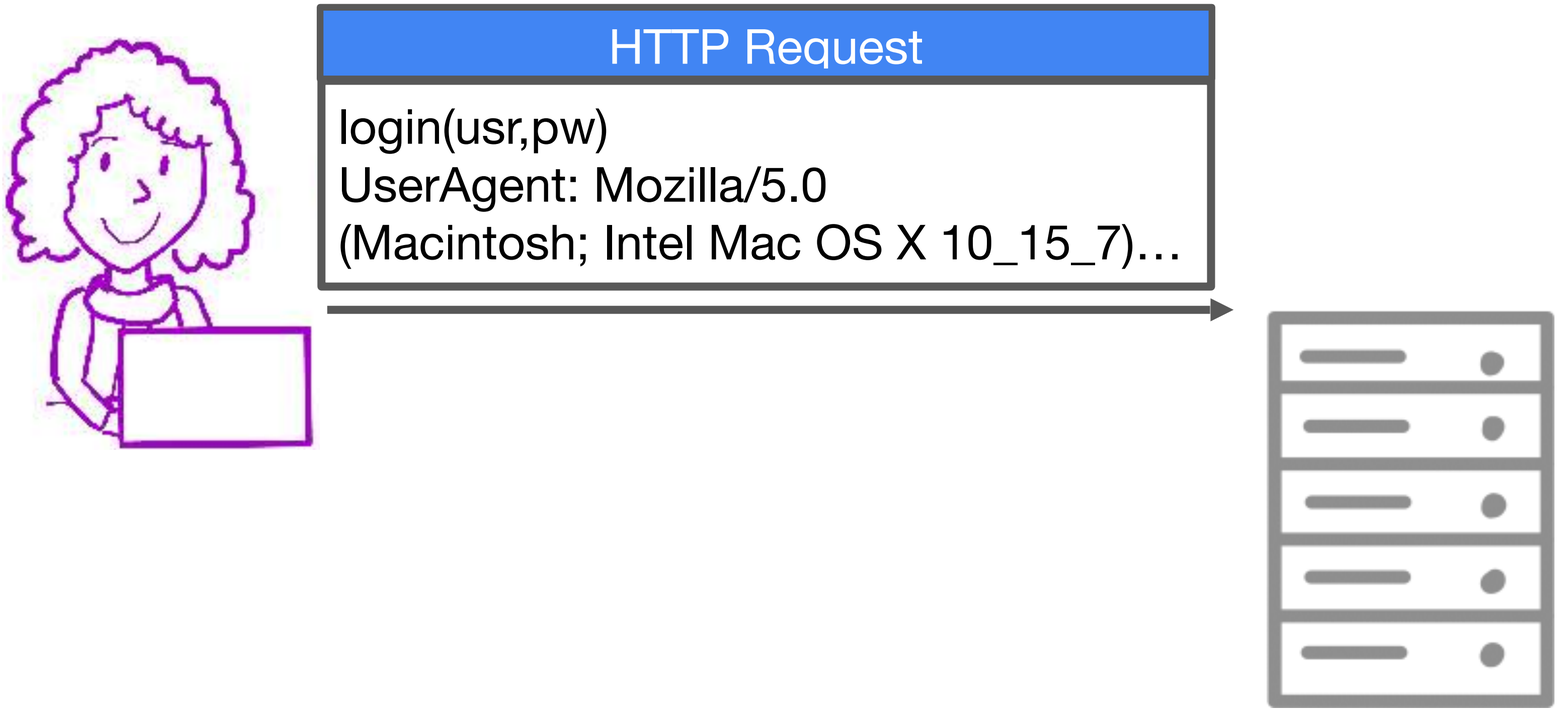




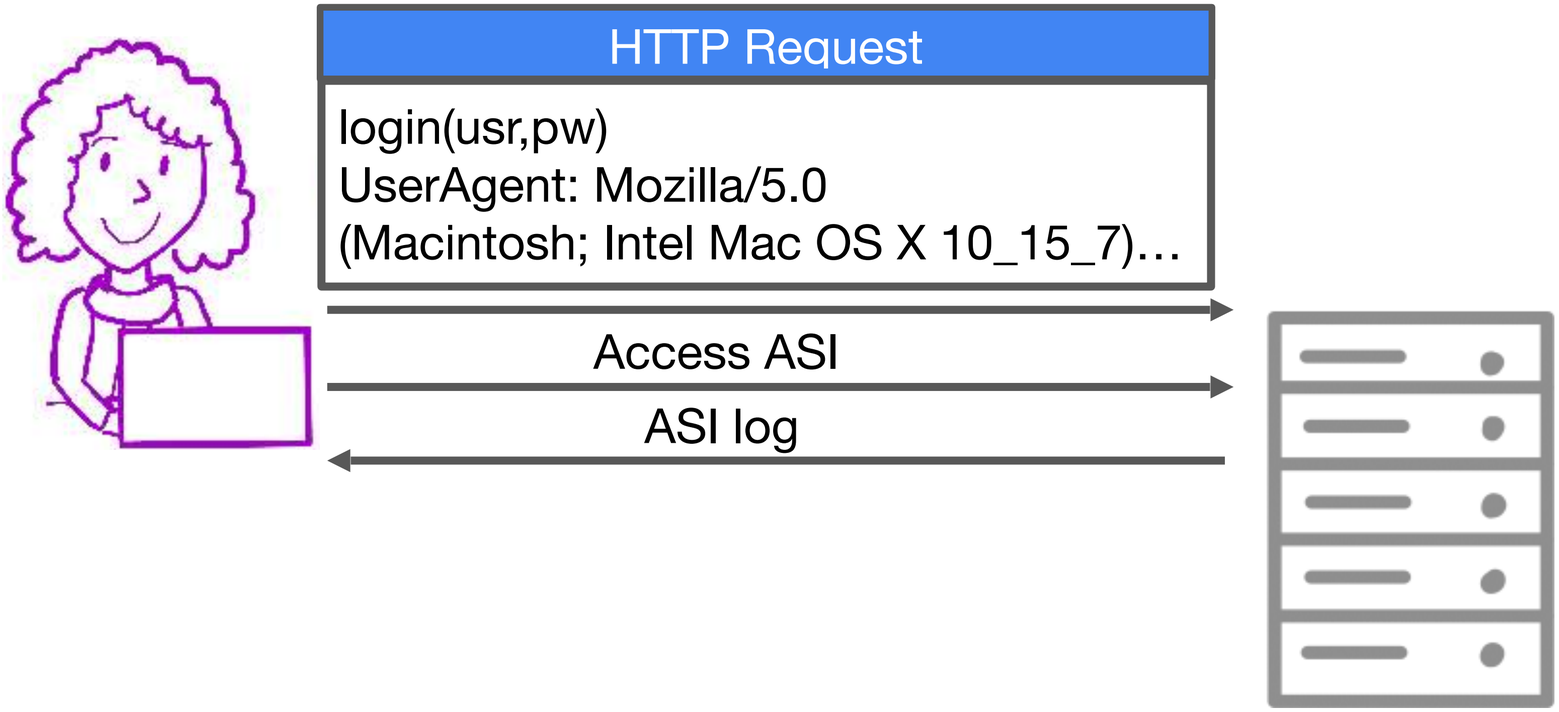


Account security interfaces (ASIs)

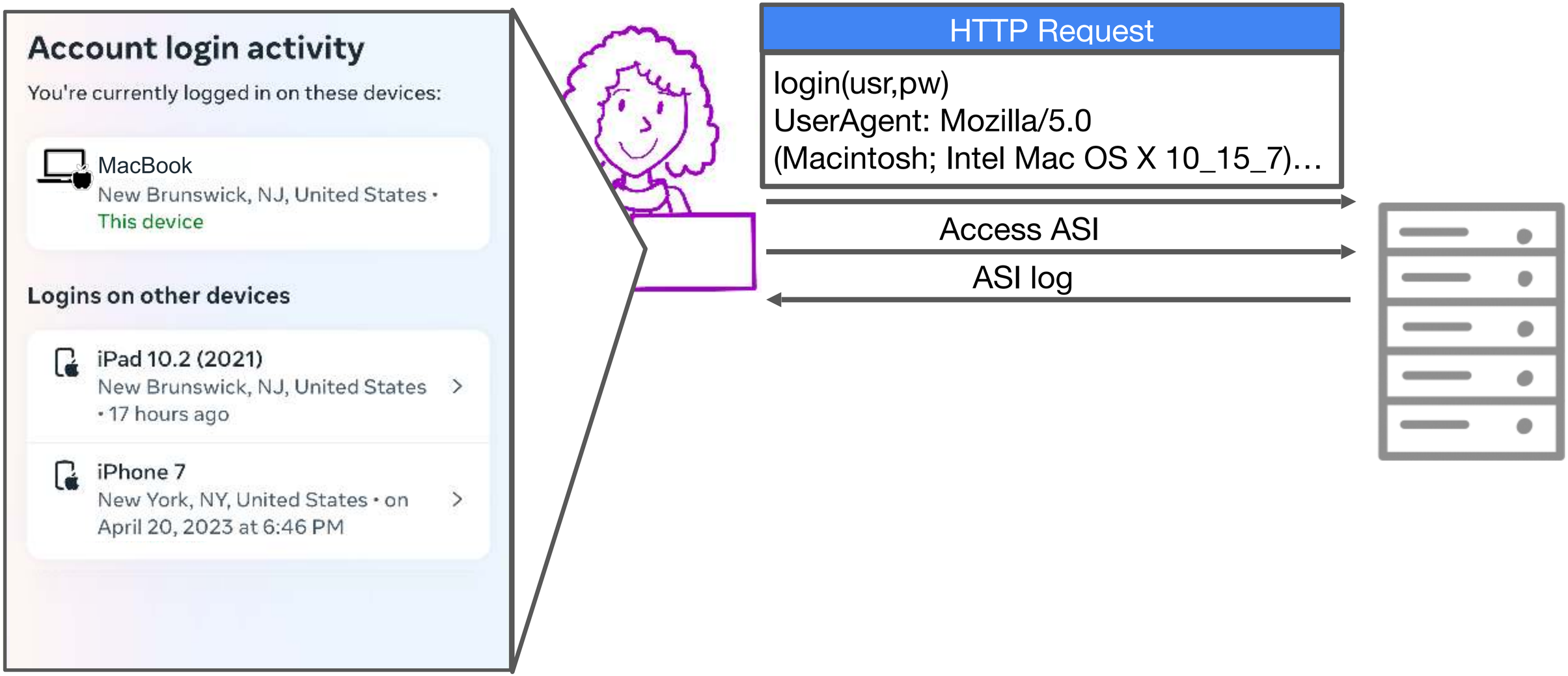
Account security interfaces (ASIs)



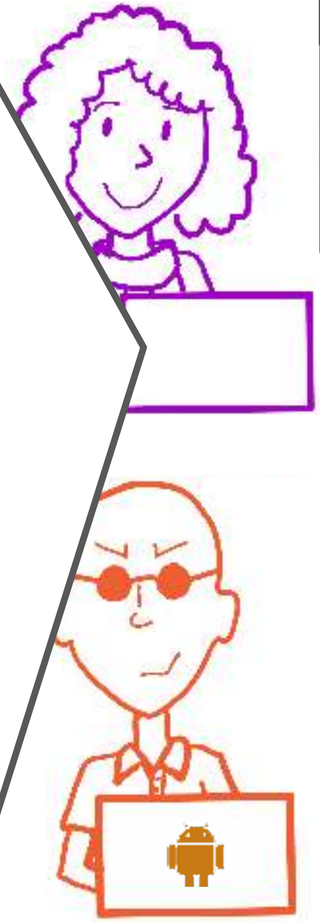
Account security interfaces (ASIs)



Account security interfaces (ASIs)



Account security interfaces (ASIs)



HTTP Request

login(usr,pw)
UserAgent: Mozilla/5.0
(Macintosh; Intel Mac OS X 10_15_7)…

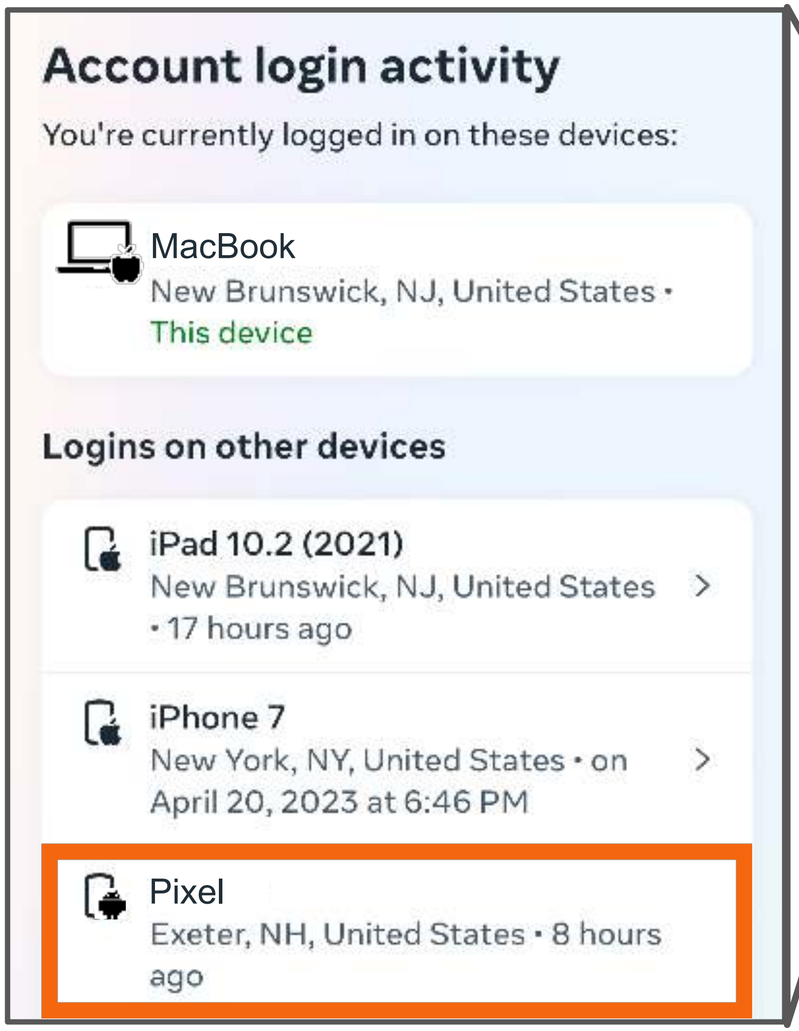
Access ASI

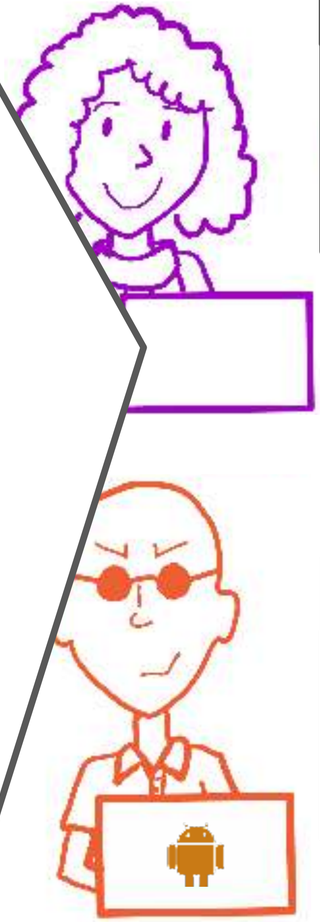
ASI log

HTTP Request

login(usr,pw)
UserAgent: Mozilla/5.0
(Linux; Android 10; Pixel 4)…

Account security interfaces (ASIs)





HTTP Request

login(usr,pw)
UserAgent: Mozilla/5.0
(Macintosh; Intel Mac OS X 10_15_7)…

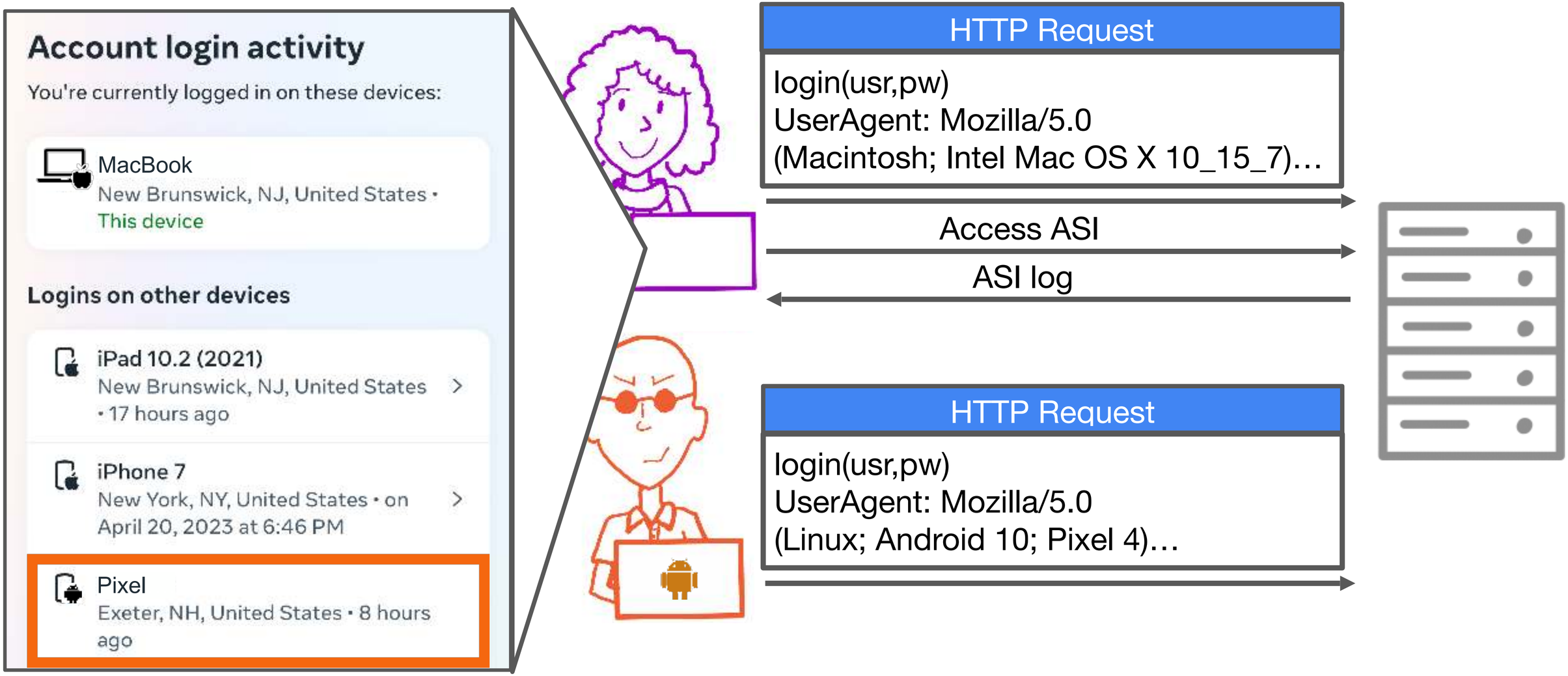
Access ASI

ASI log

HTTP Request

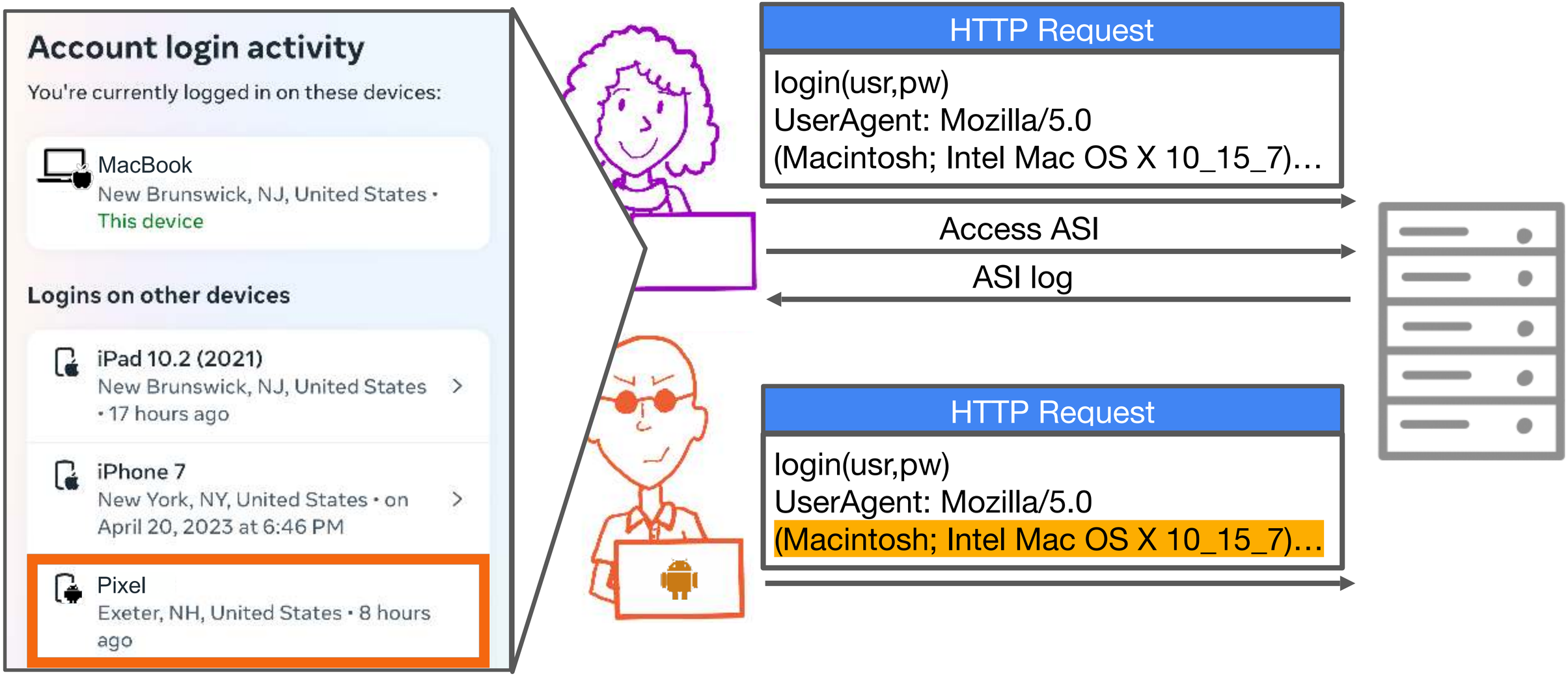
login(usr,pw)
UserAgent: Mozilla/5.0
(Linux; Android 10; Pixel 4)…

ASIs are easy to spoof



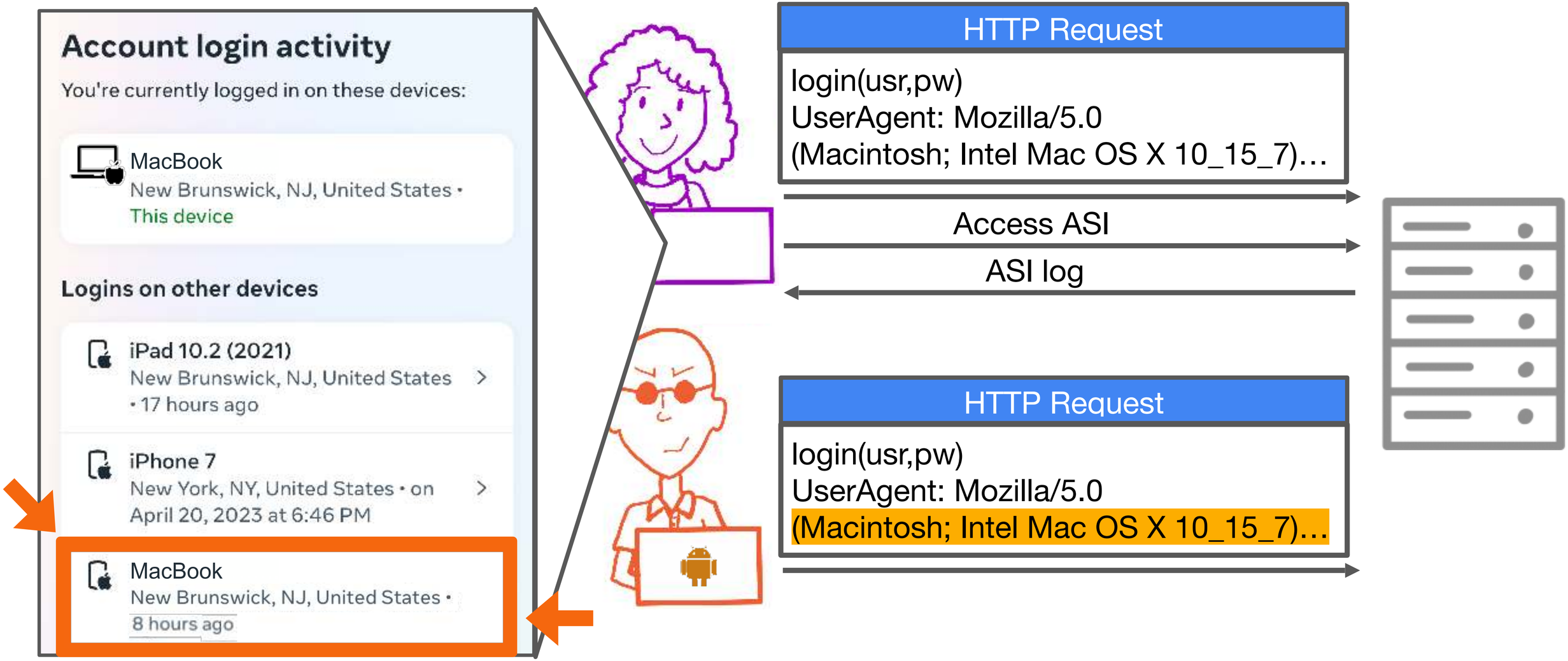
Account Security Interfaces: Important, Unintuitive, and Untrustworthy. Daffalla et al (2023)

ASIs are easy to spoof



Account Security Interfaces: Important, Unintuitive, and Untrustworthy. Daffalla et al (2023)

ASIs are easy to spoof



Account Security Interfaces: Important, Unintuitive, and Untrustworthy. Daffalla et al (2023)

Today's talk: client-side encrypted access logging

Introduce two new protocols for client-side encrypted access logging (CSAL)

- PK-CSAL
- Trace

Deployment considerations & challenges

Propose WebAuthn extension for access logging

Spoofing: Isn’t this easy to fix?

Spoofing: Isn’t this easy to fix? No.

Spoofing: Isn’t this easy to fix? No.

Idea: Send stable device identifiers (e.g., serial number) during login

Spoofing: Isn't this easy to fix? No.

Idea: Send stable device identifiers (e.g., serial number) during login

Decades of work highlighting the ***dangers of device fingerprinting***

[Eckersley 2010], [Egele et al. 2011], [Nikiforakis et al. 2013], [Acar et al. 2014], [Kurtz et al. 2016], [Yen et al. 2017] …

Spoofing: Isn’t this easy to fix? No.

Idea: Send stable device identifiers (e.g., serial number) during login

Decades of work highlighting the ***dangers of device fingerprinting***

[Eckersley 2010], [Egele et al. 2011], [Nikiforakis et al. 2013], [Acar et al. 2014], [Kurtz et al. 2016], [Yen et al. 2017] …

OS’s don't reveal device ID to apps currently

Spoofing: Isn’t this easy to fix? No.

Idea: Send stable device identifiers (e.g., serial number) during login

Decades of work highlighting the ***dangers of device fingerprinting***

[Eckersley 2010], [Egele et al. 2011], [Nikiforakis et al. 2013], [Acar et al. 2014], [Kurtz et al. 2016], [Yen et al. 2017] …

OS’s don't reveal device ID to apps currently

Best practices for working with Android identifiers

To protect the privacy of your users, use the most restrictive identifier that satisfies your app's use case. In particular, follow these best practices:

1. ***Choose user-resettable identifiers whenever possible.*** Your app can achieve most of its use cases even when it uses identifiers other than non-resettable hardware IDs.

Spoofing: Isn't this easy to fix? No.

Idea: Send stable device identifiers (e.g., serial number) during login

Decades of work highlighting the ***dangers of device fingerprinting***

[Eckersley 2010], [Egele et al. 2011], [Nikiforakis et al. 2013], [Acar et al. 2014], [Kurtz et al. 2016], [Yen et al. 2017] …

OS's don't reveal device ID to apps currently

Best practices for working with Android identifiers

To protect the privacy of your users, use the most restrictive identifier that satisfies your app's use case. In particular, follow these best practices:

1. ***Choose user-resettable identifiers whenever possible.*** Your app can achieve most of its use cases even when it uses identifiers other than non-resettable hardware IDs.

Cannot send device IDs in clear

Spoofing: Isn't this easy to fix? No.

Idea: Send stable device identifiers (e.g., serial number) during login

Decades of work highlighting the ***dangers of device fingerprinting***

[Eckersley 2010], [Egele et al. 2011], [Nikiforakis et al. 2013], [Acar et al. 2014], [Kurtz et al. 2016], [Yen et al. 2017] …

OS's don't reveal device ID to apps currently

Best practices for working with Android identifiers

To protect the privacy of your users, use the most restrictive identifier that satisfies your app's use case. In particular, follow these best practices:

1. ***Choose user-resettable identifiers whenever possible.*** Your app can achieve most of its use cases even when it uses identifiers other than non-resettable hardware IDs.

Cannot send device IDs in clear

Need OS support

PK-CSAL

USENIX’25

Encrypted Access Logging for Online Accounts: Device Attributions without Device Tracking.
Ortega Pérez, Daffalla, and Ristenpart (2025)

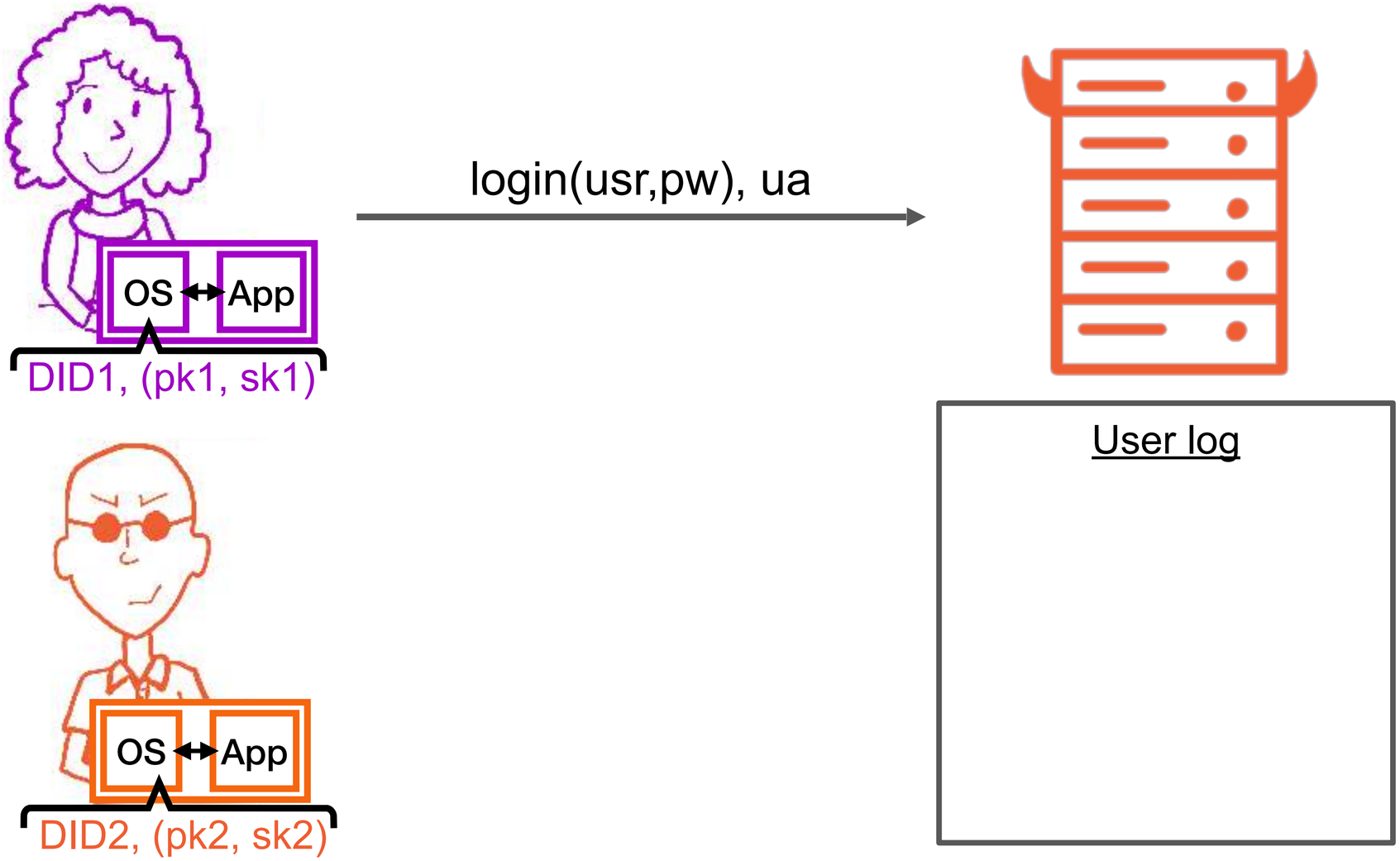
PK-CSAL

User log

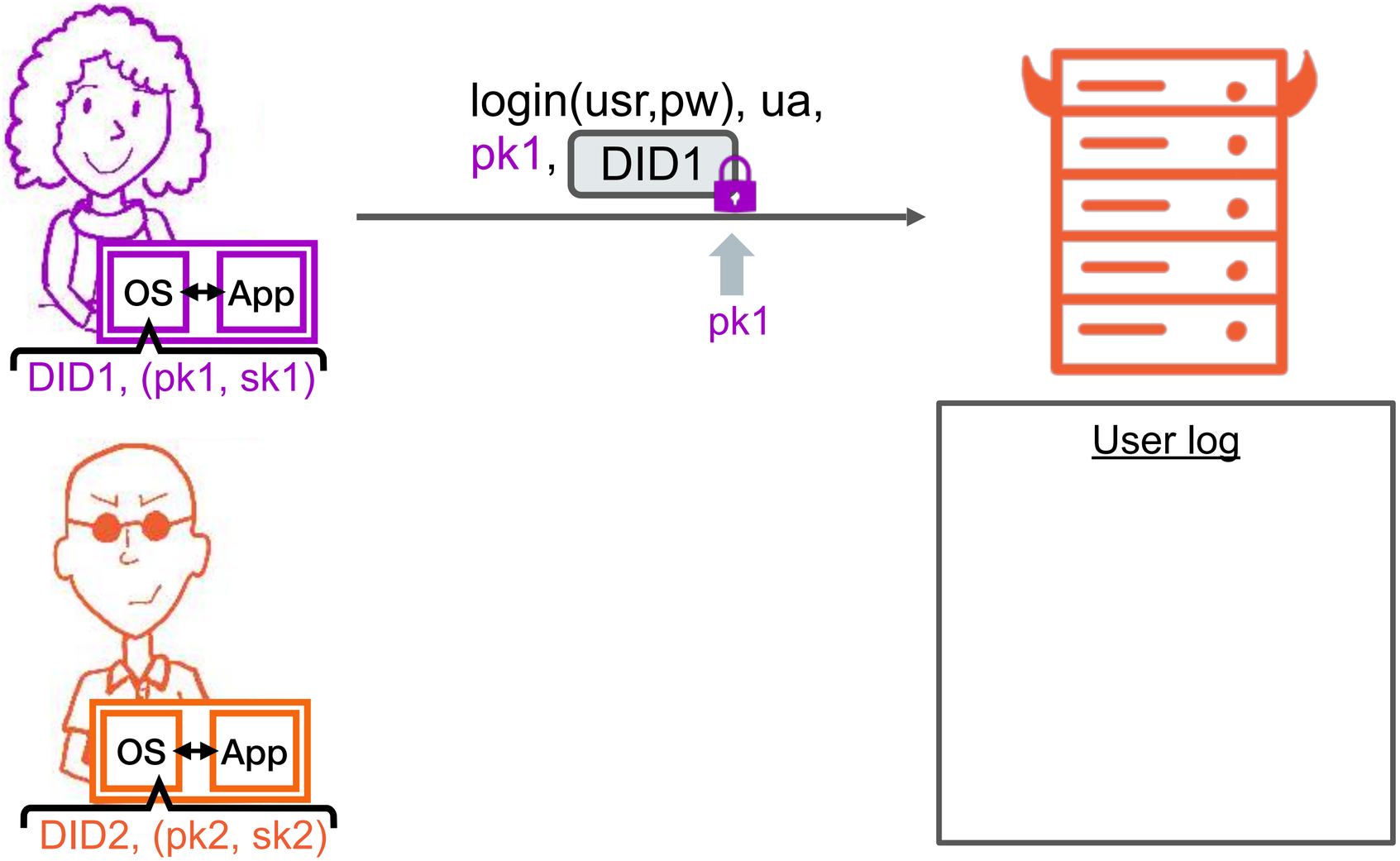
PK-CSAL

User log

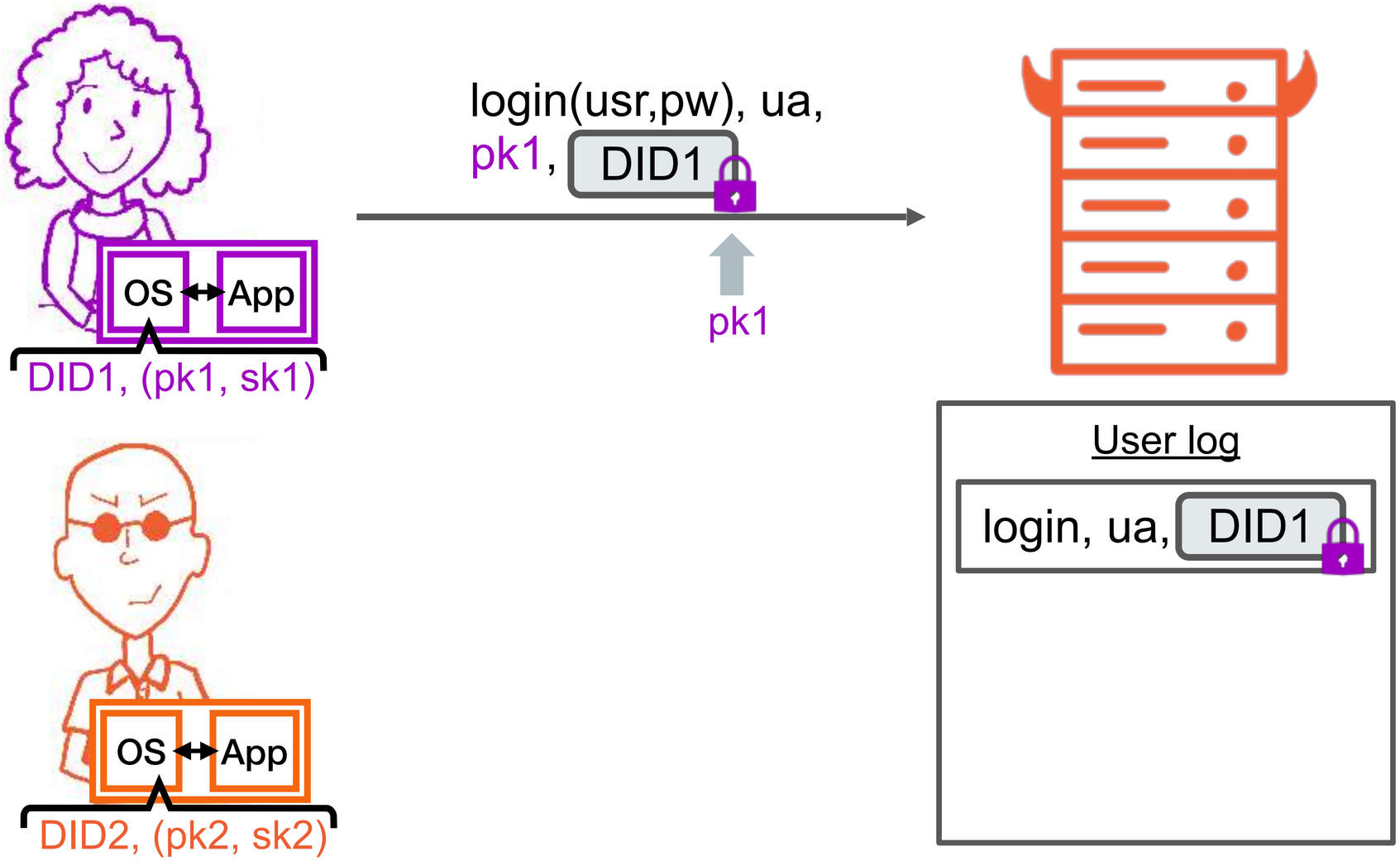
PK-CSAL



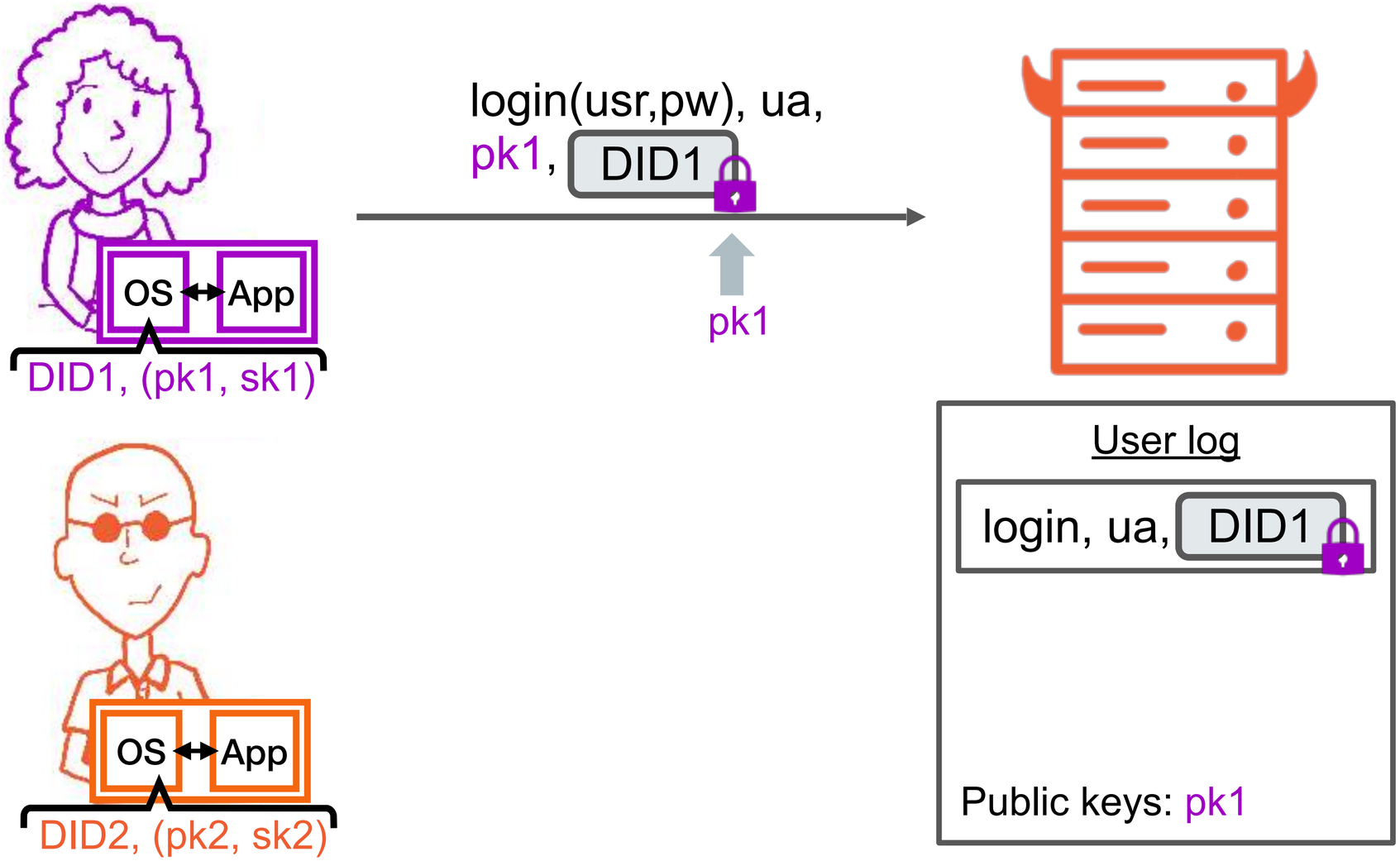
PK-CSAL


OS
App
DID1, (pk1, sk1)
login(usr,pw), ua,
pk1, DID1
pk1
User log
OS
App
DID2, (pk2, sk2)

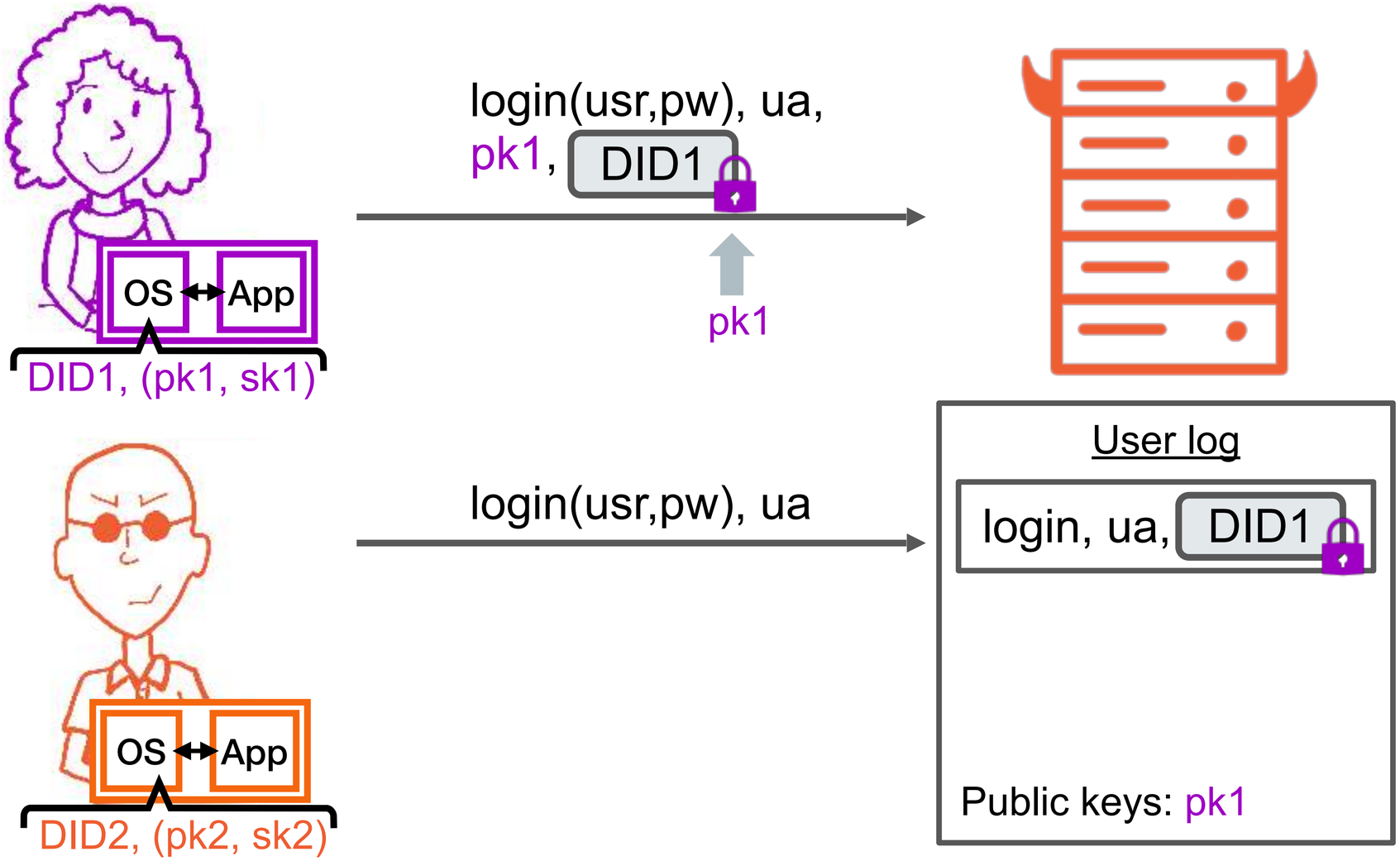
PK-CSAL


OS
App
DID1, (pk1, sk1)
login(usr,pw), ua,
pk1, DID1
pk1
OS
App
DID2, (pk2, sk2)
User log
login, ua, DID1

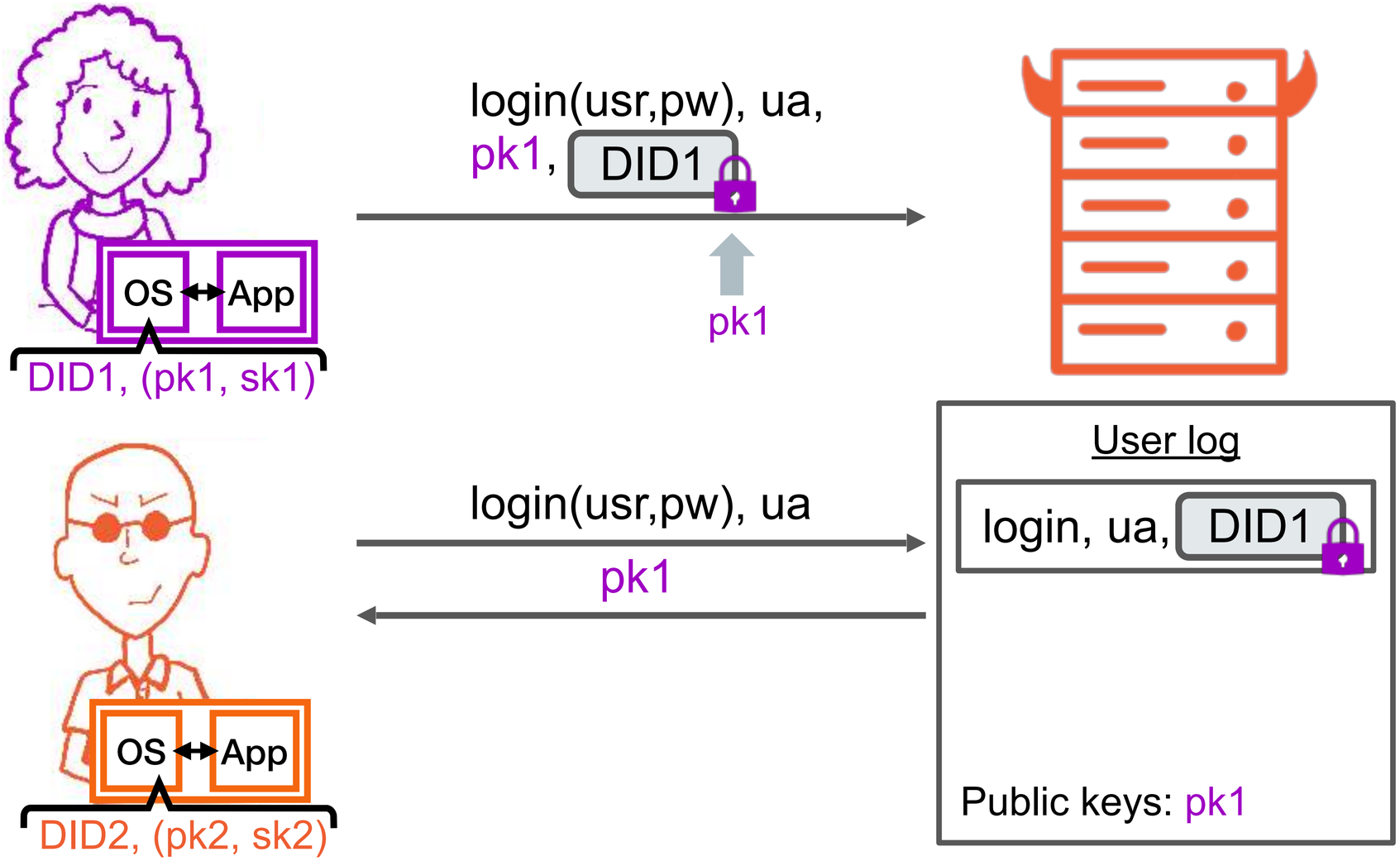
PK-CSAL


OS
App
DID1, (pk1, sk1)
login(usr,pw), ua,
pk1, DID1
pk1
OS
App
DID2, (pk2, sk2)
User log
login, ua, DID1
Public keys: pk1

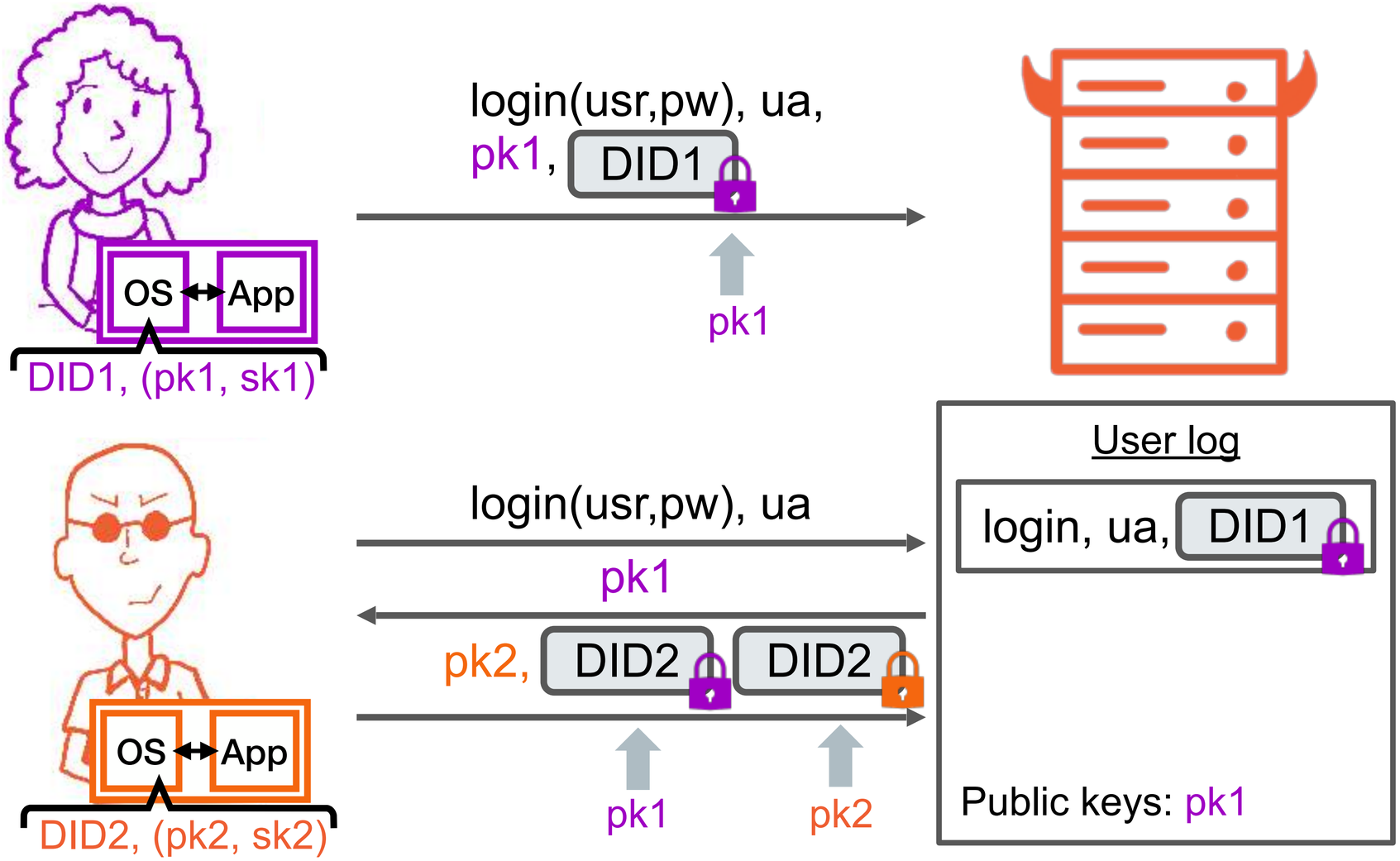
PK-CSAL


OS
App
DID1, (pk1, sk1)
login(usr,pw), ua,
pk1, DID1
pk1
OS
App
DID2, (pk2, sk2)
login(usr,pw), ua
User log
login, ua, DID1
Public keys: pk1

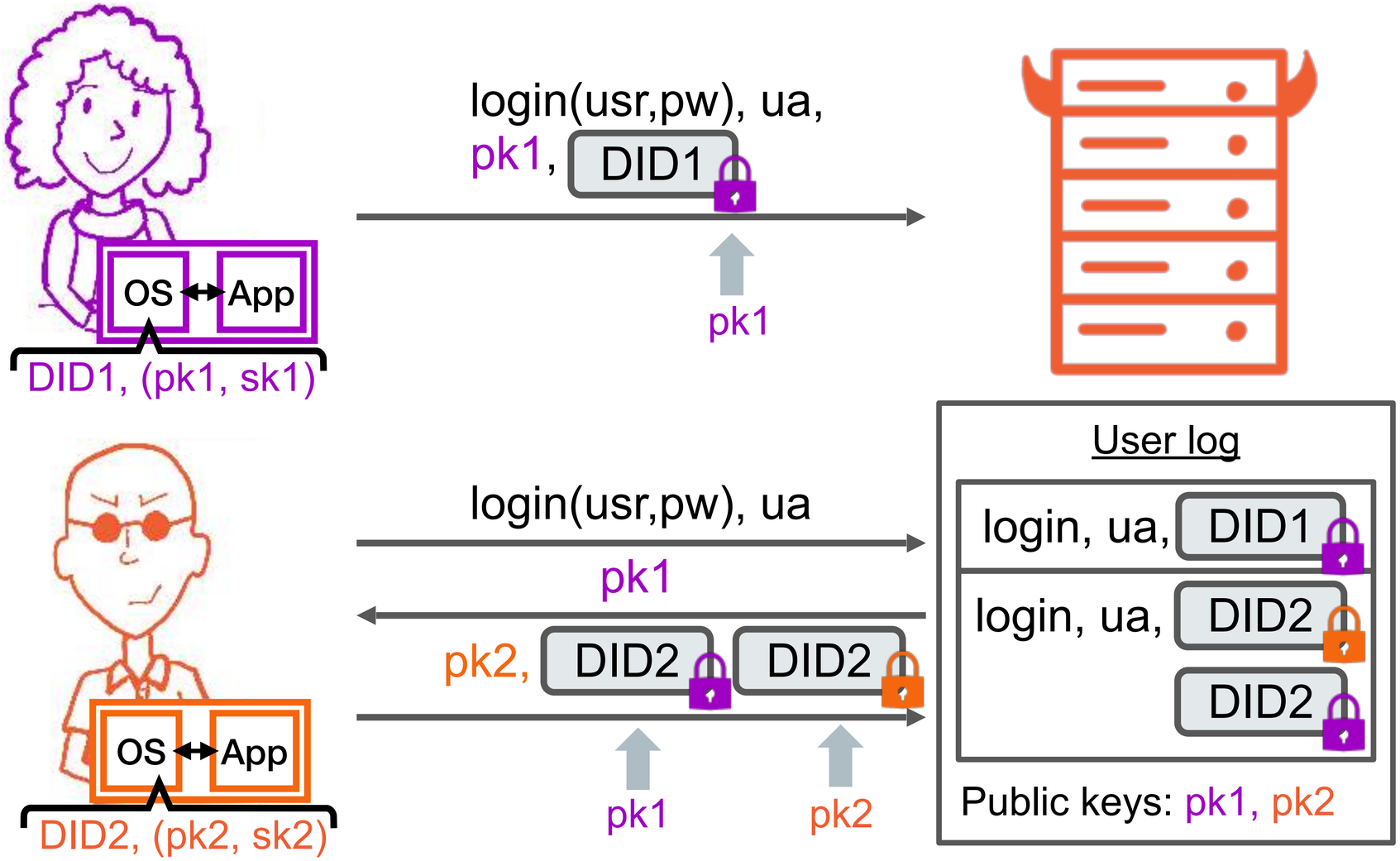
PK-CSAL


OS
App
DID1, (pk1, sk1)
login(usr,pw), ua,
pk1, DID1
pk1
OS
App
DID2, (pk2, sk2)
login(usr,pw), ua
pk1
User log
login, ua, DID1
Public keys: pk1

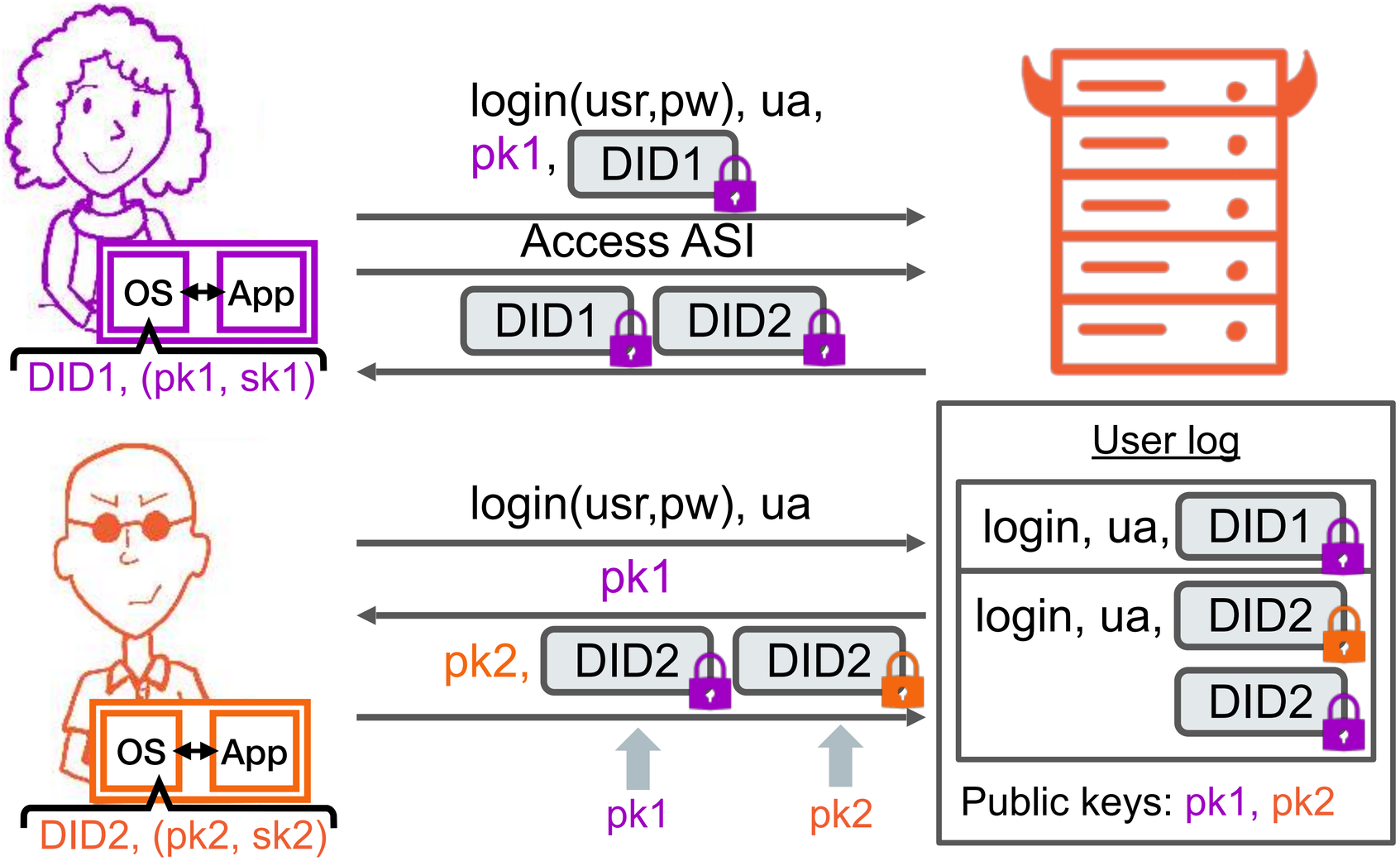
PK-CSAL


OS
App
DID1, (pk1, sk1)
login(usr,pw), ua,
pk1, DID1
pk1
OS
App
DID2, (pk2, sk2)
login(usr,pw), ua
pk1
pk2, DID2 DID2
pk1
pk2
User log
login, ua, DID1
Public keys: pk1

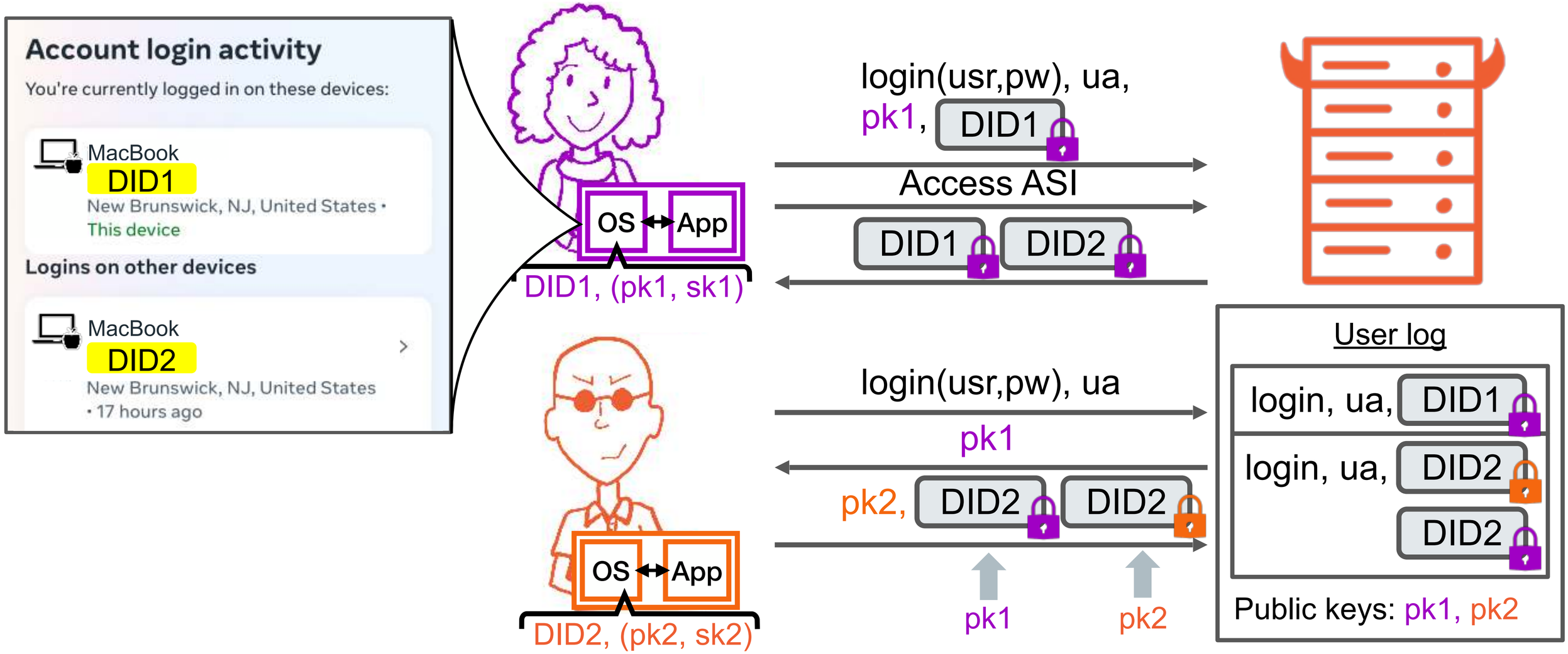
PK-CSAL


OS
App
DID1, (pk1, sk1)
login(usr,pw), ua,
pk1, DID1
pk1
OS
App
DID2, (pk2, sk2)
login(usr,pw), ua
pk1
pk2, DID2 DID2
pk1
pk2
User log
login, ua, DID1
login, ua, DID2
DID2
Public keys: pk1, pk2

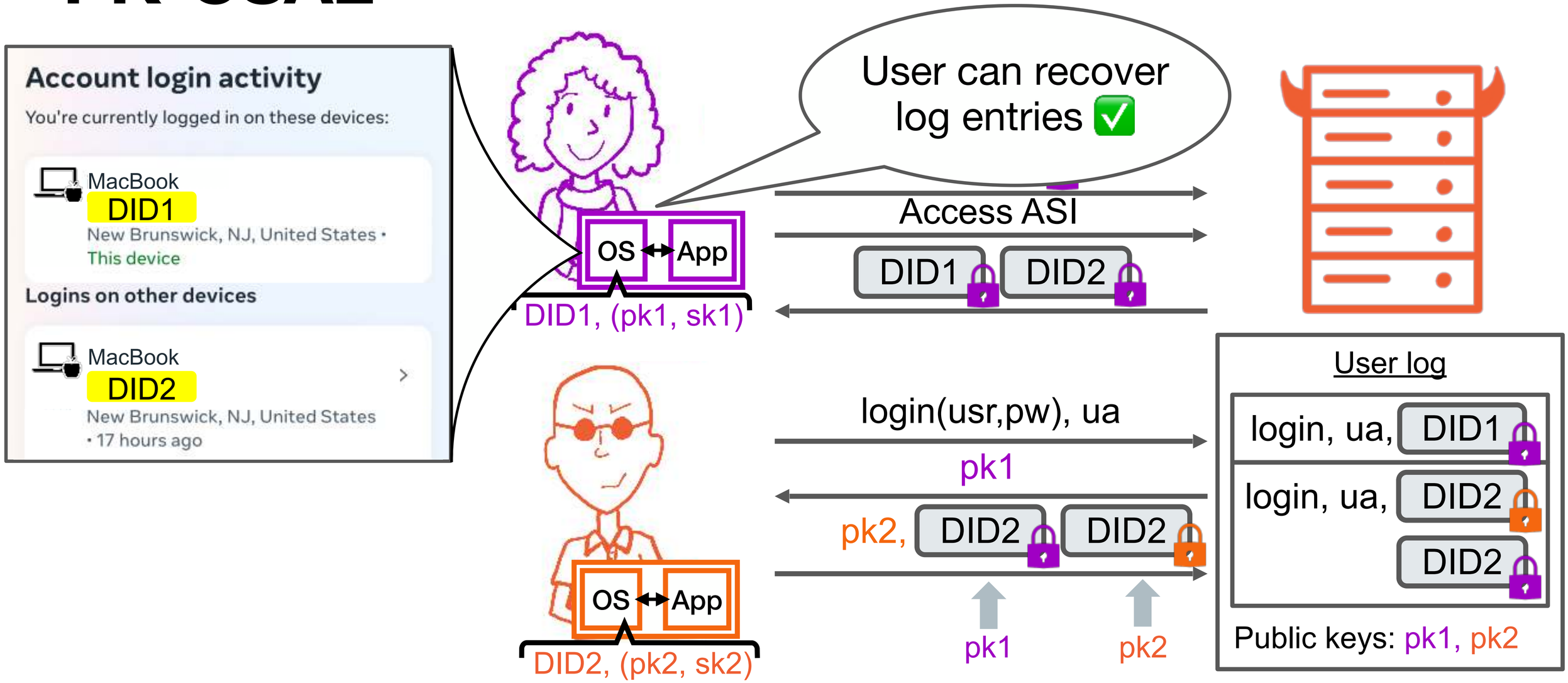
PK-CSAL


login(usr,pw), ua,
pk1,
DID1
Access ASI
DID1
DID2
OS
App
DID1, (pk1, sk1)
login(usr,pw), ua
pk1
pk2,
DID2
DID2
OS
App
DID2, (pk2, sk2)
pk1
pk2
User log
login, ua,
DID1
login, ua,
DID2
DID2
Public keys: pk1, pk2

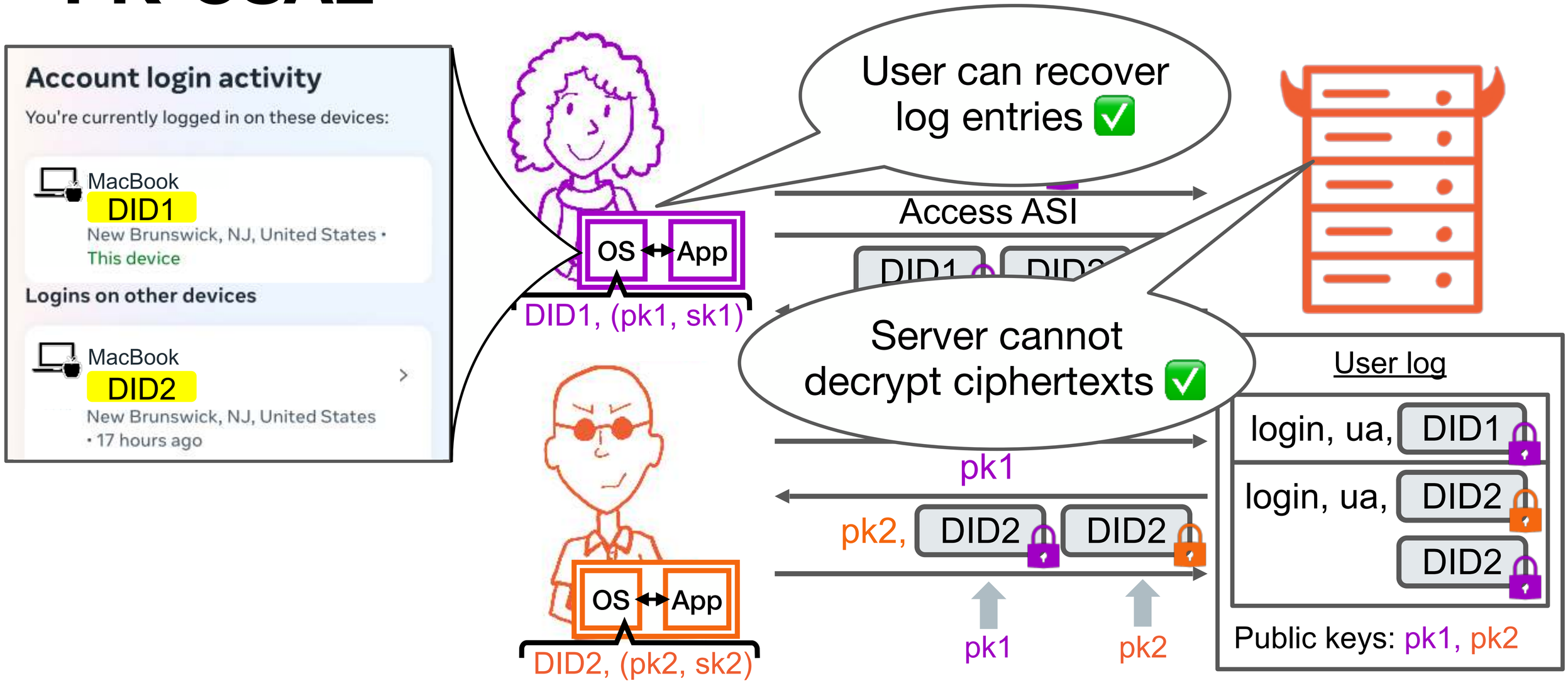
PK-CSAL


Account login activity
You're currently logged in on these devices:
MacBook
DID1
New Brunswick, NJ, United States •
This device
Logins on other devices
MacBook
DID2
New Brunswick, NJ, United States
• 17 hours ago
OS
App
DID1, (pk1, sk1)
login(usr,pw), ua,
pk1,
DID1
Access ASI
DID1
DID2
OS
App
DID2, (pk2, sk2)
login(usr,pw), ua
pk1
pk2,
DID2
DID2
pk1
pk2
User log
login, ua,
DID1
login, ua,
DID2
DID2
Public keys: pk1, pk2

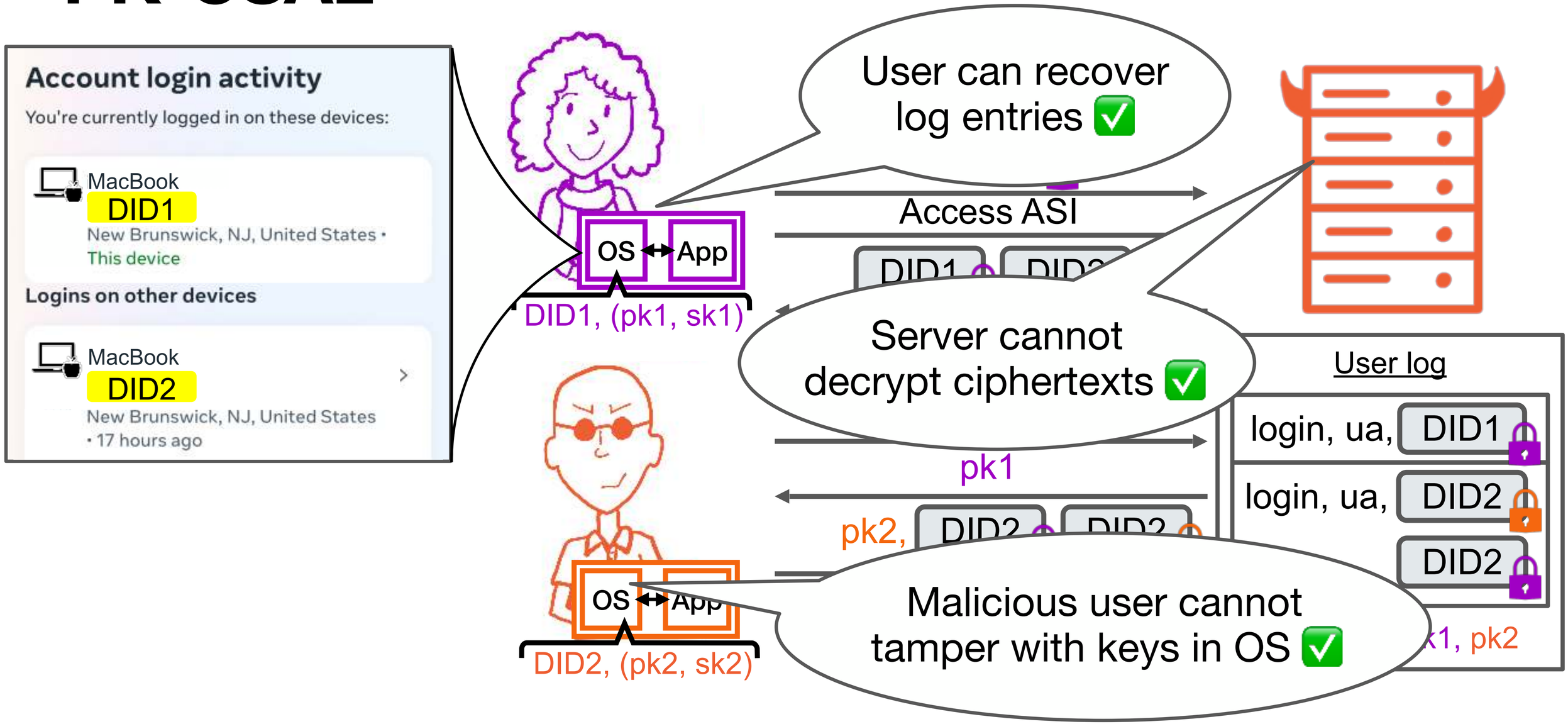
PK-CSAL


Account login activity
You're currently logged in on these devices:
MacBook
DID1
New Brunswick, NJ, United States •
This device
Logins on other devices
MacBook
DID2
New Brunswick, NJ, United States
• 17 hours ago
OS
App
DID1, (pk1, sk1)
User can recover log entries ✅
Access ASI
DID1
DID2
login(usr,pw), ua
pk1
pk2,
DID2
DID2
pk1
pk2
OS
App
DID2, (pk2, sk2)
User log
login, ua,
DID1
login, ua,
DID2
DID2
Public keys: pk1, pk2

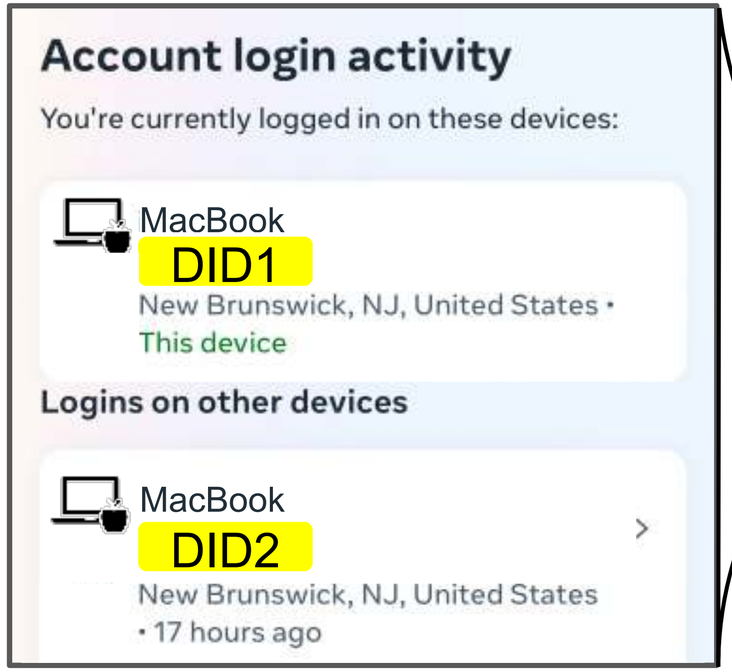
PK-CSAL

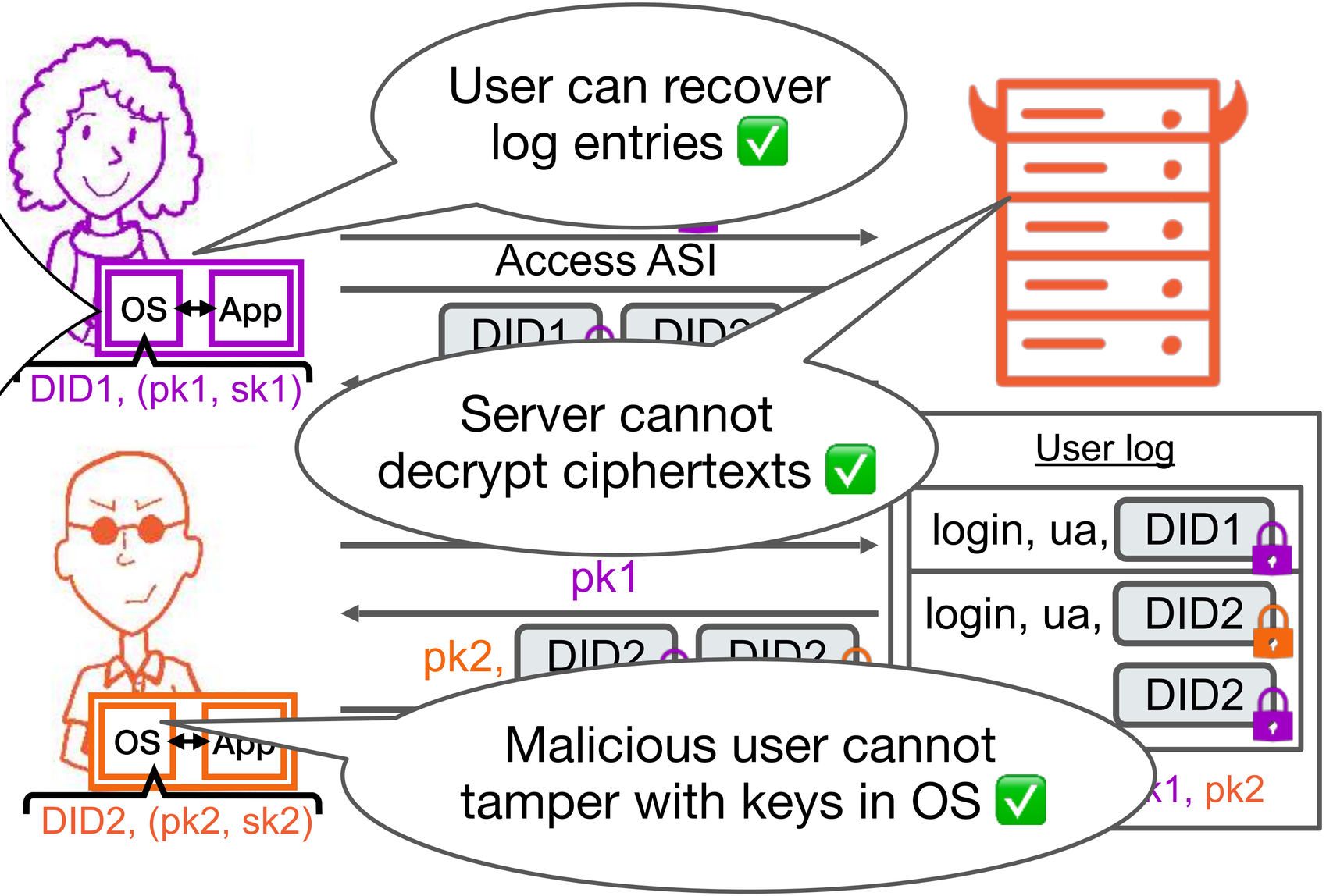

Account login activity
You're currently logged in on these devices:
MacBook
DID1
New Brunswick, NJ, United States •
This device
Logins on other devices
MacBook
DID2
New Brunswick, NJ, United States
• 17 hours ago
OS
App
DID1, (pk1, sk1)
User can recover log entries ✅
Access ASI
Server cannot decrypt ciphertexts ✅
pk1
pk2,
DID2
DID2
pk1
pk2
OS
App
DID2, (pk2, sk2)
User log
login, ua,
DID1
login, ua,
DID2
DID2
Public keys: pk1, pk2

PK-CSAL


Account login activity
You're currently logged in on these devices:
MacBook
DID1
New Brunswick, NJ, United States •
This device
Logins on other devices
MacBook
DID2
New Brunswick, NJ, United States
• 17 hours ago
OS
App
DID1, (pk1, sk1)
User can recover log entries ✅
Access ASI
Server cannot decrypt ciphertexts ✅
pk1
pk2,
OS
App
DID2, (pk2, sk2)
Malicious user cannot tamper with keys in OS ✅
User log
login, ua, DID1
login, ua, DID2
DID2

PK-CSAL





Gossip protocol for newer sessions to decrypt older entries

Formal treatment of CSAL

$\underline{\text{PRIV}_{\Pi}(\mathcal{D})}$

$st_{\text{rp}} \leftarrow\$ \mathcal{I}_s$; $b \leftarrow\$ \{0,1\}$

$b' \leftarrow\$ \mathcal{D}^{\mathcal{O}}(st_{\text{rp}})$

Return

$\underline{\text{UNLINK}_{\Pi}(\mathcal{D})}$

$b \leftarrow\$ \{0,1\}$

$st_{\text{rp}} \leftarrow\$ \mathcal{I}_s$

$b' \leftarrow\$ \mathcal{D}^{\mathcal{O}}(st_{\text{rp}})$

Return

$\underline{\text{LIS}_{\Pi,\text{prune}}(\mathcal{A})}$

$st_{\text{rp}} \leftarrow\$ \mathcal{I}_s$; win $\leftarrow 0$

$\mathcal{A}^{\mathcal{O}}$

Return win

$\underline{\text{InitClient}}$

$\mu \leftarrow \mu + 1$; $st_{\mu} \leftarrow\$ \mathcal{I}_c$

$\underline{\text{Login}(c, \text{OS}, \text{CL}, \text{RP})}$

If $c > \mu$ then Return $\perp$

$(sid, st_c, st_{\text{rp}}) \leftarrow\$ \mathcal{L}((st_c, \text{OS}, \text{C}$

$\gamma_{c,sid} \leftarrow$ True

$q \leftarrow q + 1$

$\mathcal{T}^*[q] \leftarrow (\text{INIT}, c, sid, \text{OS}, \text{CL}, \text{R}$

Return (sid, st_c)

$\underline{\text{Action}(c, sid, \text{OS}, \text{CL}, \text{RP})}$

If $\gamma_{c,sid} = \perp$ then Return $\perp$

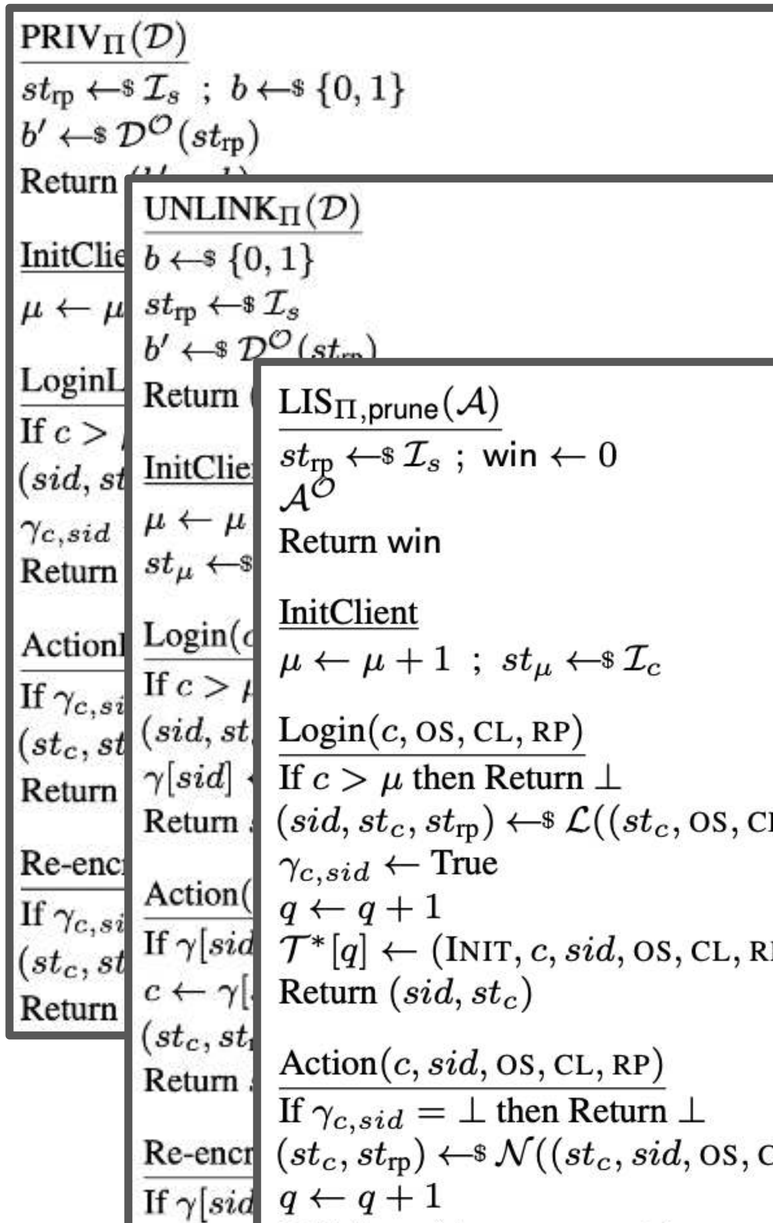
$(st_c, st_{\text{rp}}) \leftarrow\$ \mathcal{N}((st_c, sid, \text{OS}, \text{C}$

$q \leftarrow q + 1$

Encrypted Access Logging for Online Accounts: Device Attributions without Device Tracking. Ortega Pérez, Daffalla, and Ristenpart (2025)

Formal treatment of CSAL

- **Log privacy** and **session unlinkability** against server
- **“Ability to access”** log entries



Encrypted Access Logging for Online Accounts: Device Attributions without Device Tracking. Ortega Pérez, Daffalla, and Ristenpart (2025)

Formal treatment of CSAL

- **Log privacy** and **session unlinkability** against server
- **"Ability to access"** log entries

Theorem

Cannot have privacy and access all log entries in all situations.

$\underline{\text{PRIV}_{\Pi}(\mathcal{D})}$

$st_{\text{rp}} \leftarrow\$ \mathcal{I}_s$; $b \leftarrow\$ \{0,1\}$

$b' \leftarrow\$ \mathcal{D}^{\mathcal{O}}(st_{\text{rp}})$

Return

$\underline{\text{UNLINK}_{\Pi}(\mathcal{D})}$

$b \leftarrow\$ \{0,1\}$

$st_{\text{rp}} \leftarrow\$ \mathcal{I}_s$

$b' \leftarrow\$ \mathcal{D}^{\mathcal{O}}(st_{\text{rp}})$

Return

$\underline{\text{LIS}_{\Pi,\text{prune}}(\mathcal{A})}$

$st_{\text{rp}} \leftarrow\$ \mathcal{I}_s$; win $\leftarrow 0$

$\mathcal{A}^{\mathcal{O}}$

Return win

$\underline{\text{InitClient}}$

$\mu \leftarrow \mu + 1$; $st_{\mu} \leftarrow\$ \mathcal{I}_c$

$\underline{\text{Login}(c, \text{OS}, \text{CL}, \text{RP})}$

If $c > \mu$ then Return $\perp$

$(sid, st_c, st_{\text{rp}}) \leftarrow\$ \mathcal{L}((st_c, \text{OS}, \text{C}$

$\gamma_{c,sid} \leftarrow$ True

$q \leftarrow q + 1$

$\mathcal{T}^*[q] \leftarrow (\text{INIT}, c, sid, \text{OS}, \text{CL}, \text{R}$

Return (sid, st_c)

$\underline{\text{Action}(c, sid, \text{OS}, \text{CL}, \text{RP})}$

If $\gamma_{c,sid} = \perp$ then Return $\perp$

$(st_c, st_{\text{rp}}) \leftarrow\$ \mathcal{N}((st_c, sid, \text{OS}, \text{C}$

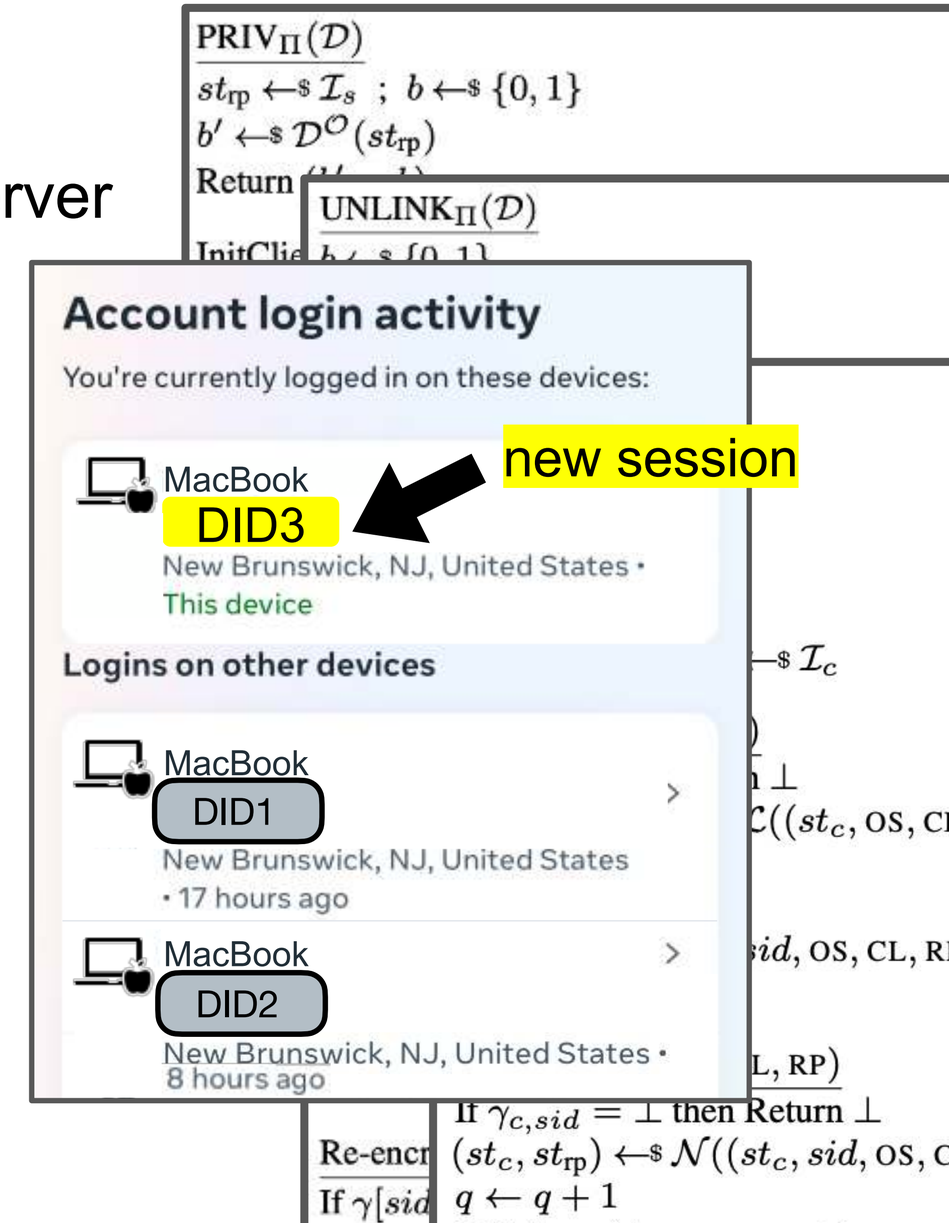
$q \leftarrow q + 1$

Encrypted Access Logging for Online Accounts: Device Attributions without Device Tracking. Ortega Pérez, Daffalla, and Ristenpart (2025)

Formal treatment of CSAL

- **Log privacy** and **session unlinkability** against server
- **"Ability to access"** log entries

Theorem
Cannot have privacy and access all log entries in all situations.

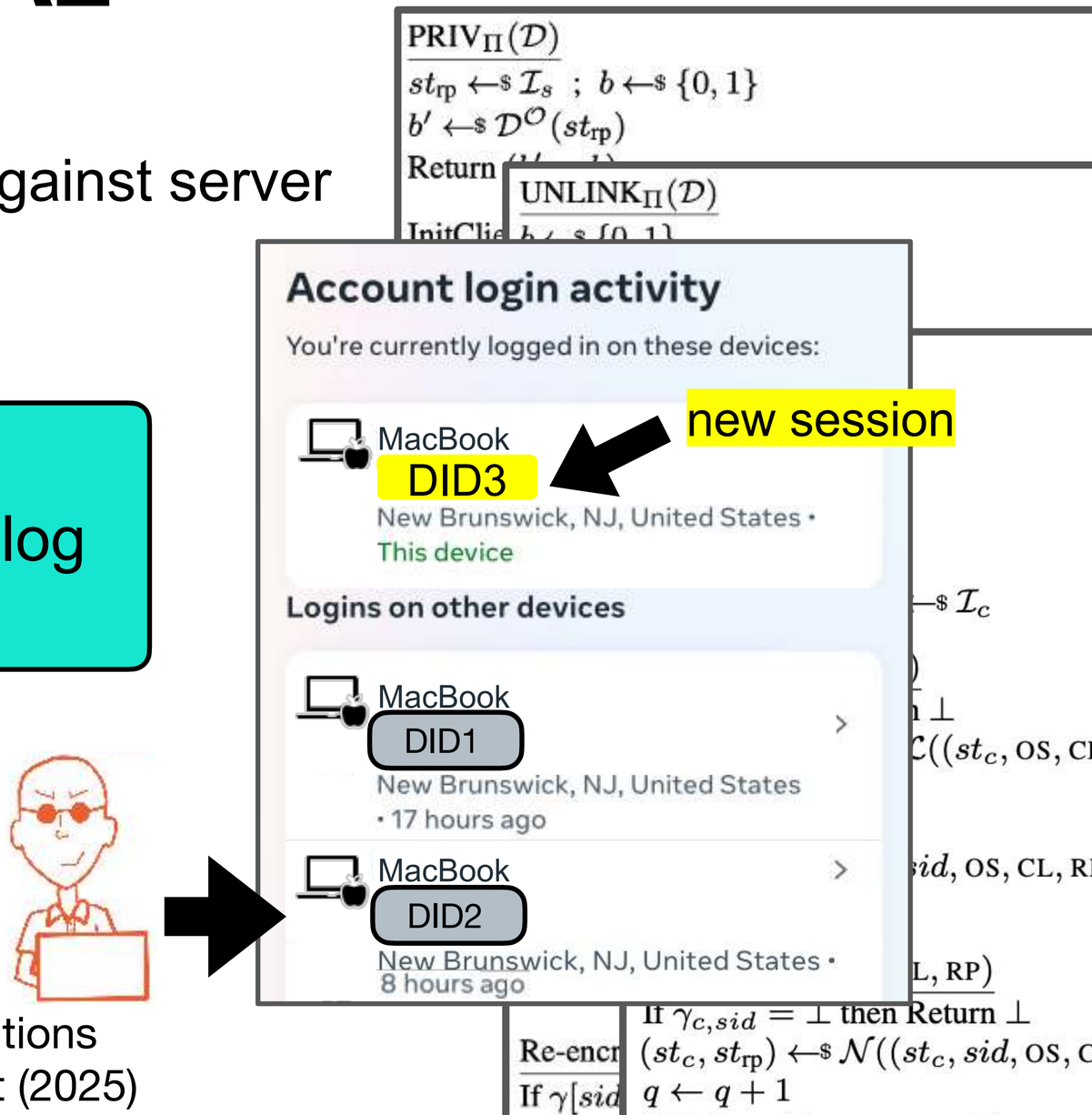


Encrypted Access Logging for Online Accounts: Device Attributions without Device Tracking. Ortega Pérez, Daffalla, and Ristenpart (2025)

Formal treatment of CSAL

- **Log privacy** and **session unlinkability** against server
- **"Ability to access"** log entries

Theorem
Cannot have privacy and access all log entries in all situations.



Encrypted Access Logging for Online Accounts: Device Attributions without Device Tracking. Ortega Pérez, Daffalla, and Ristenpart (2025)

PK-CSAL limitations

PK-CSAL limitations

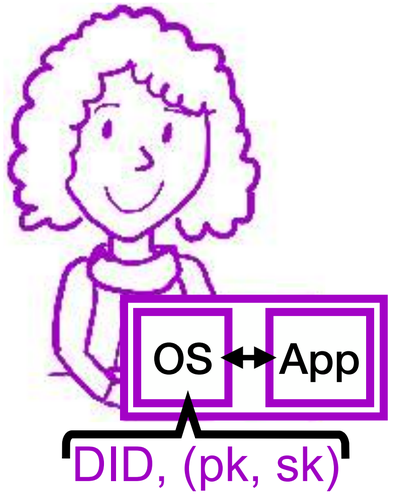
1. Not all log entries accessible in all situations

PK-CSAL limitations

1. Not all log entries accessible in all situations
2. The problem of "ghost users"

PK-CSAL limitations

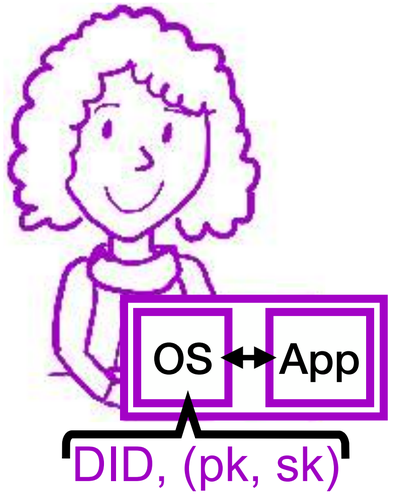
1. Not all log entries accessible in all situations
2. The problem of "ghost users"



PK-CSAL limitations

1. Not all log entries accessible in all situations
2. The problem of "ghost users"

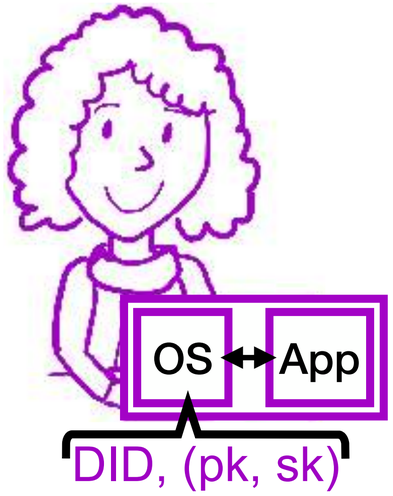
Service controls authentication:
Can add new malicious devices to account
(Similar to issue in E2EE messaging)



PK-CSAL limitations

1. Not all log entries accessible in all situations
2. The problem of "ghost users"

Service controls authentication:
Can add new malicious devices to account
(Similar to issue in E2EE messaging)

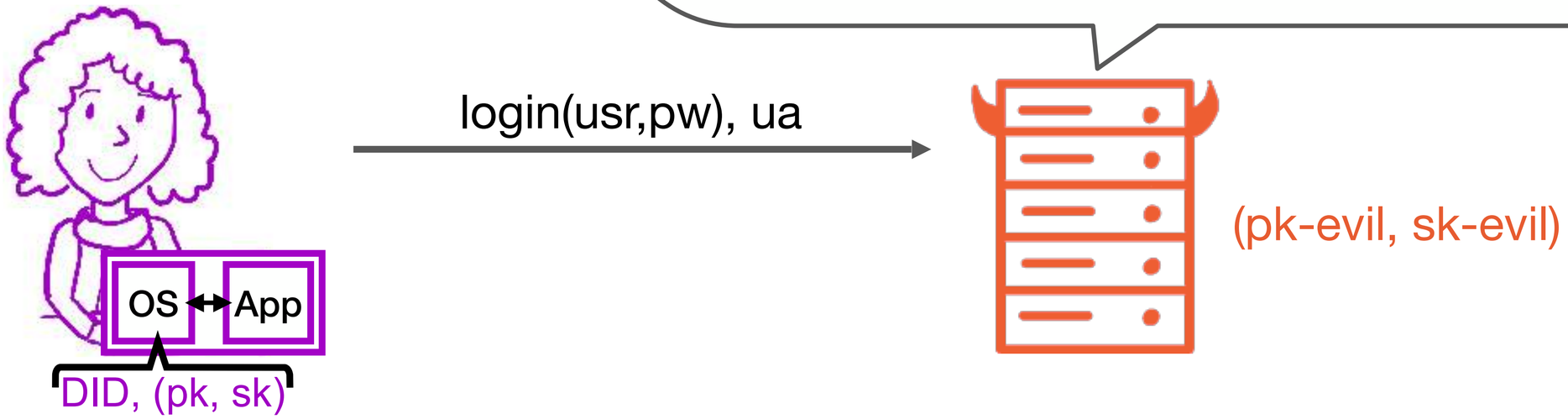


(pk-evil, sk-evil)

PK-CSAL limitations

1. Not all log entries accessible in all situations
2. The problem of "ghost users"

Service controls authentication:
Can add new malicious devices to account
(Similar to issue in E2EE messaging)



PK-CSAL limitations

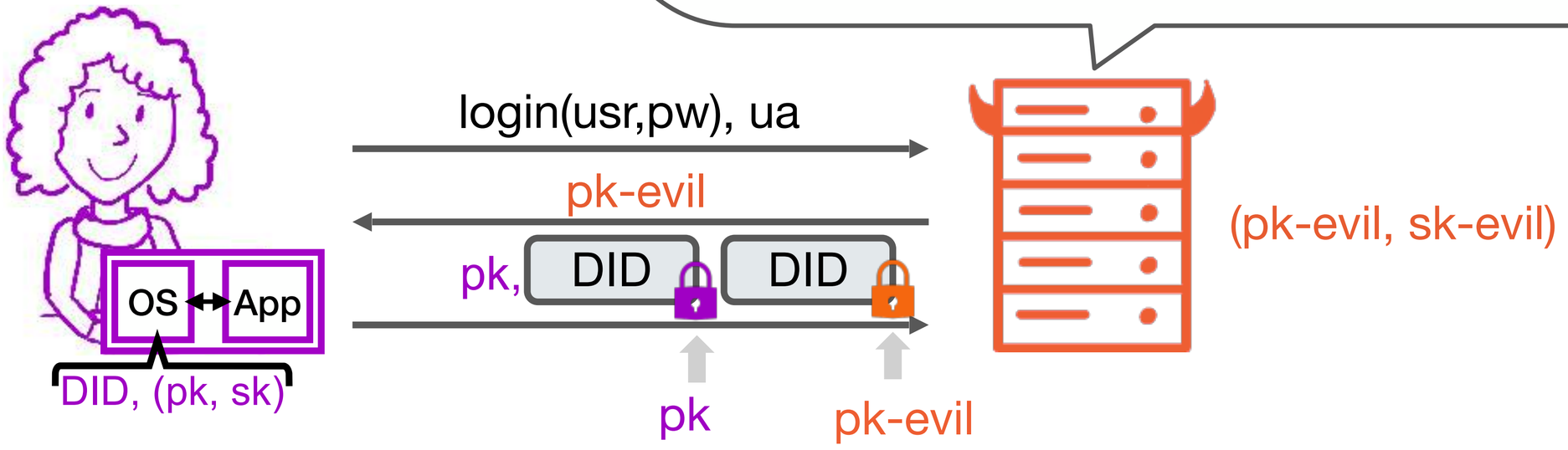
1. Not all log entries accessible in all situations
2. The problem of "ghost users"

Service controls authentication:
Can add new malicious devices to account
(Similar to issue in E2EE messaging)

PK-CSAL limitations

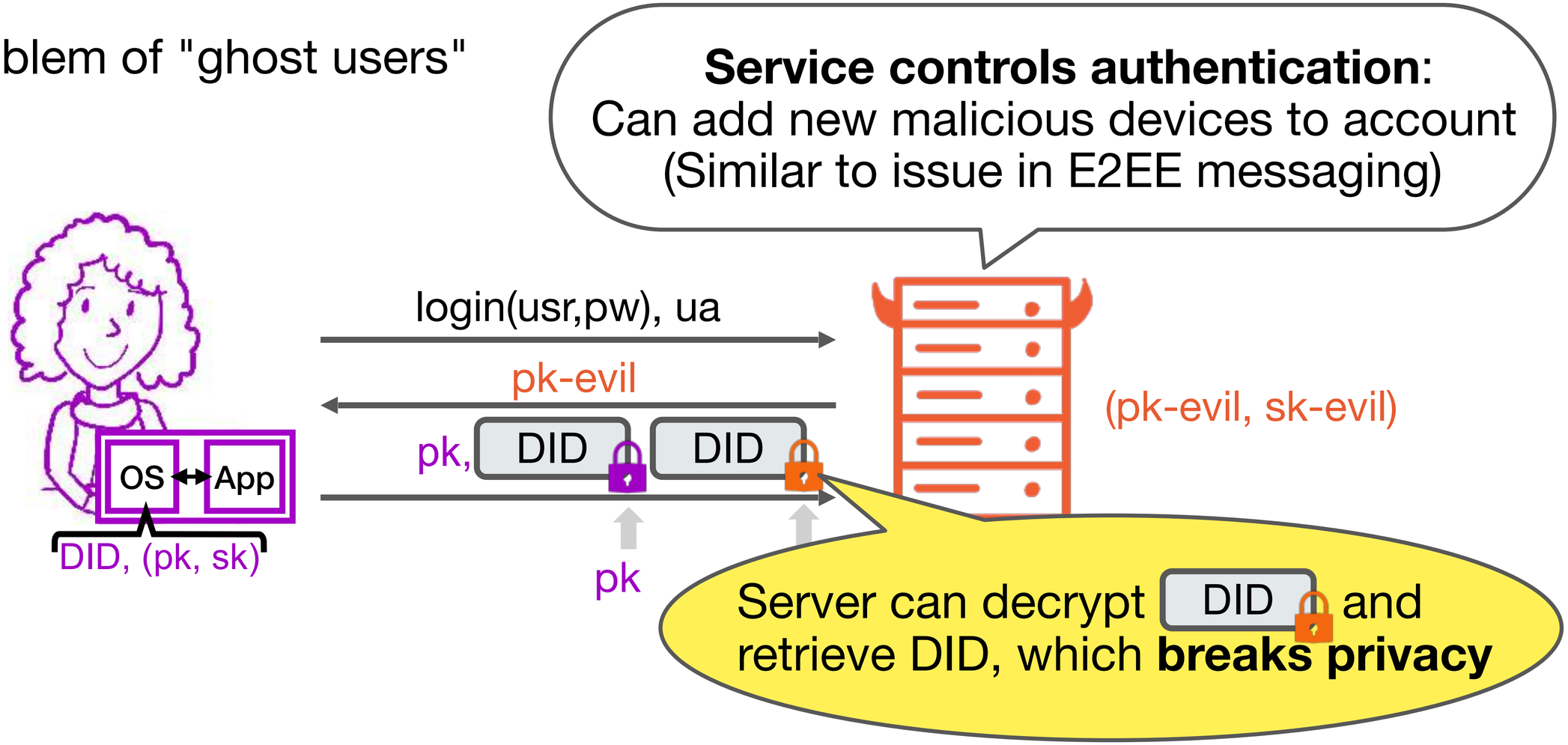
1. Not all log entries accessible in all situations
2. The problem of "ghost users"

Service controls authentication:
Can add new malicious devices to account
(Similar to issue in E2EE messaging)



PK-CSAL limitations

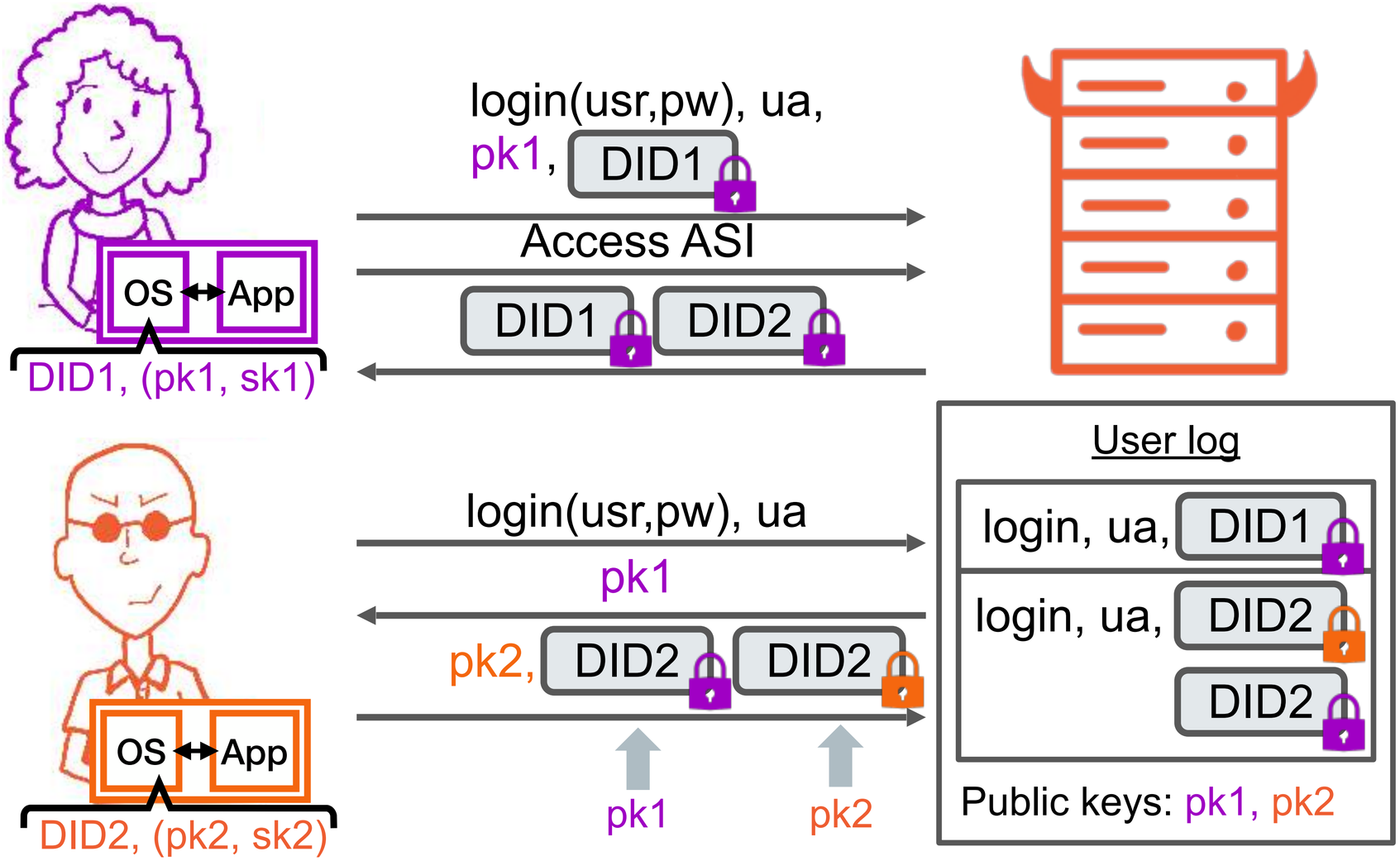
1. Not all log entries accessible in all situations
2. The problem of "ghost users"



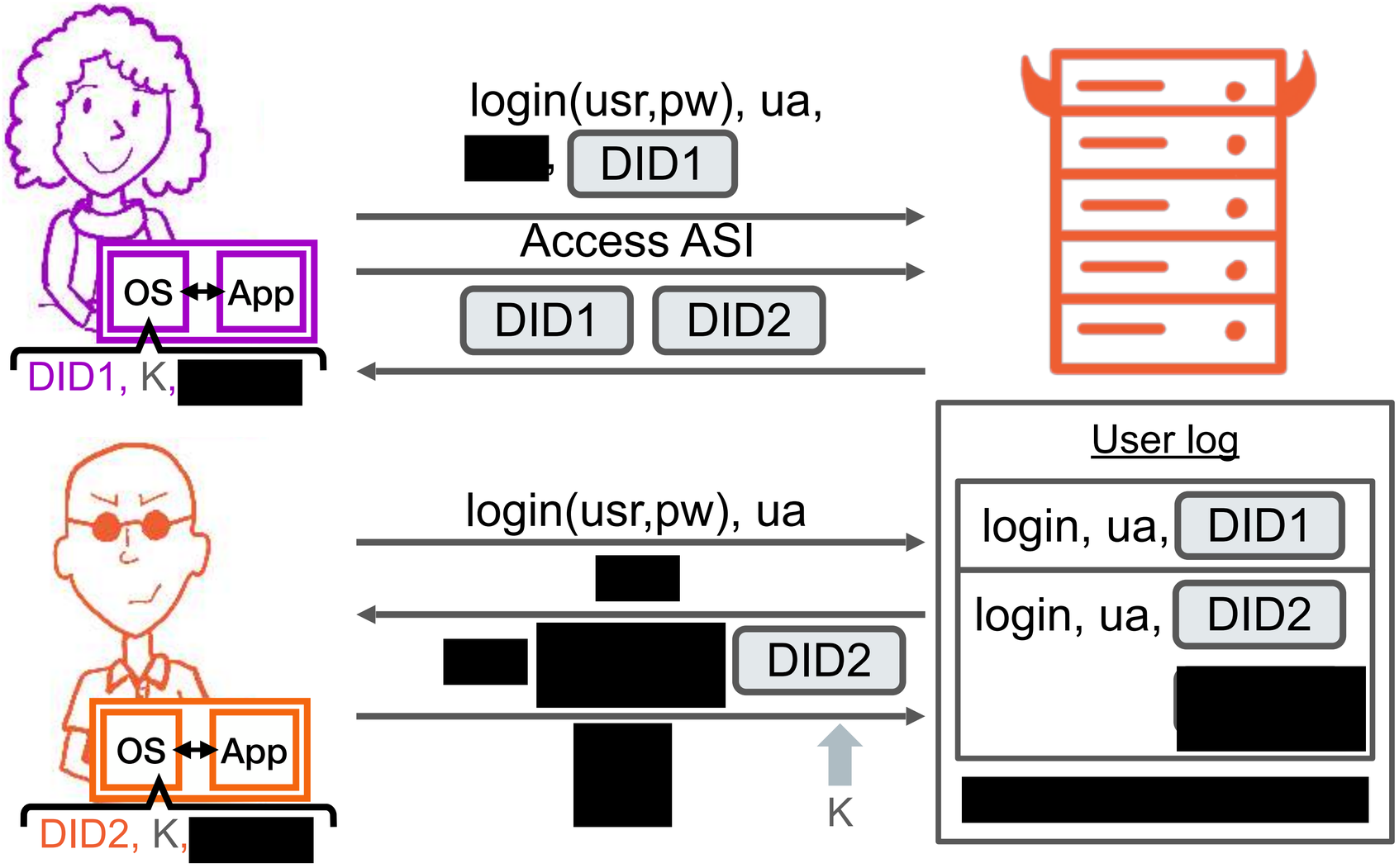
Trace

eprint.iacr.org/2026/447

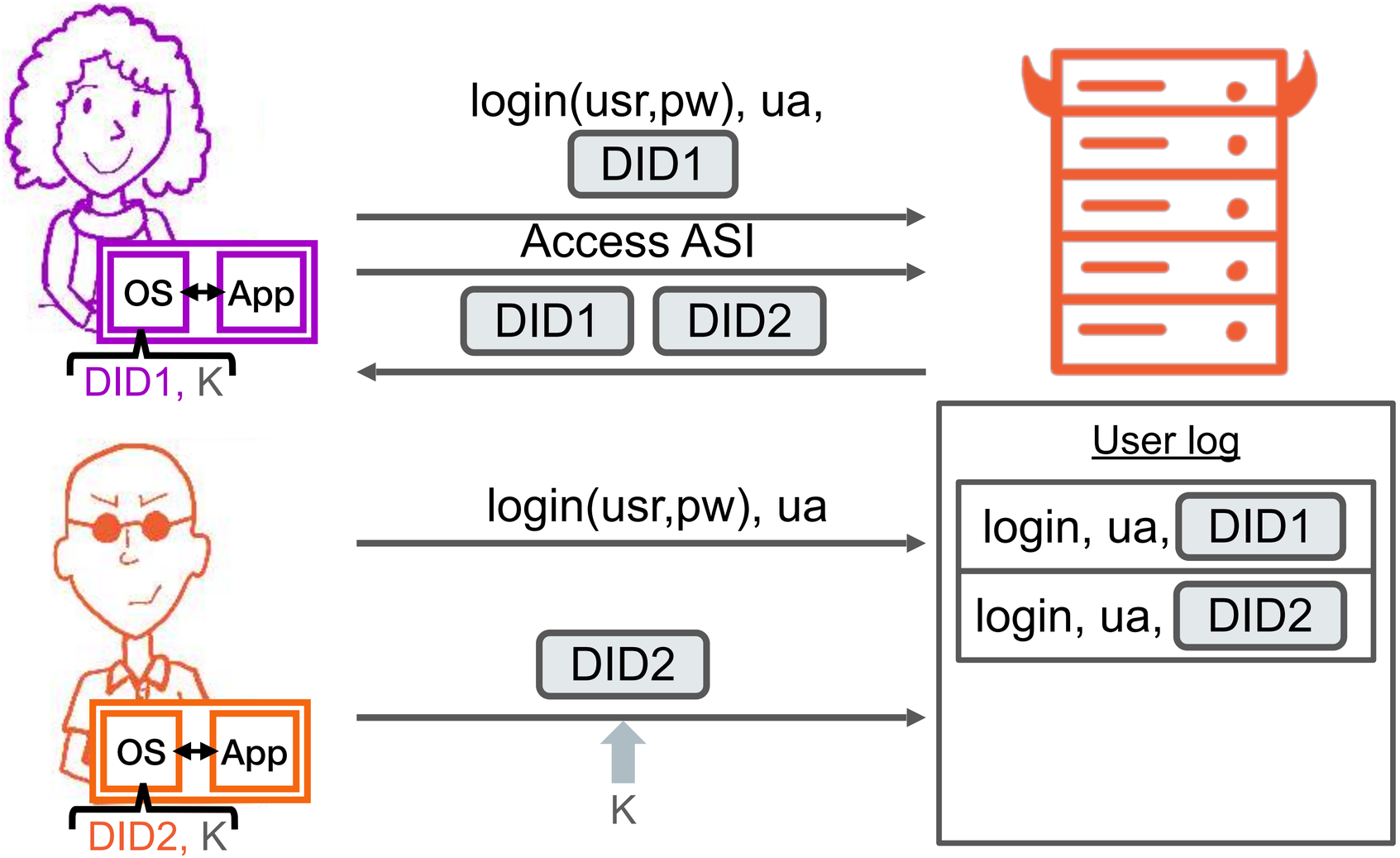
Towards a complete CSAL



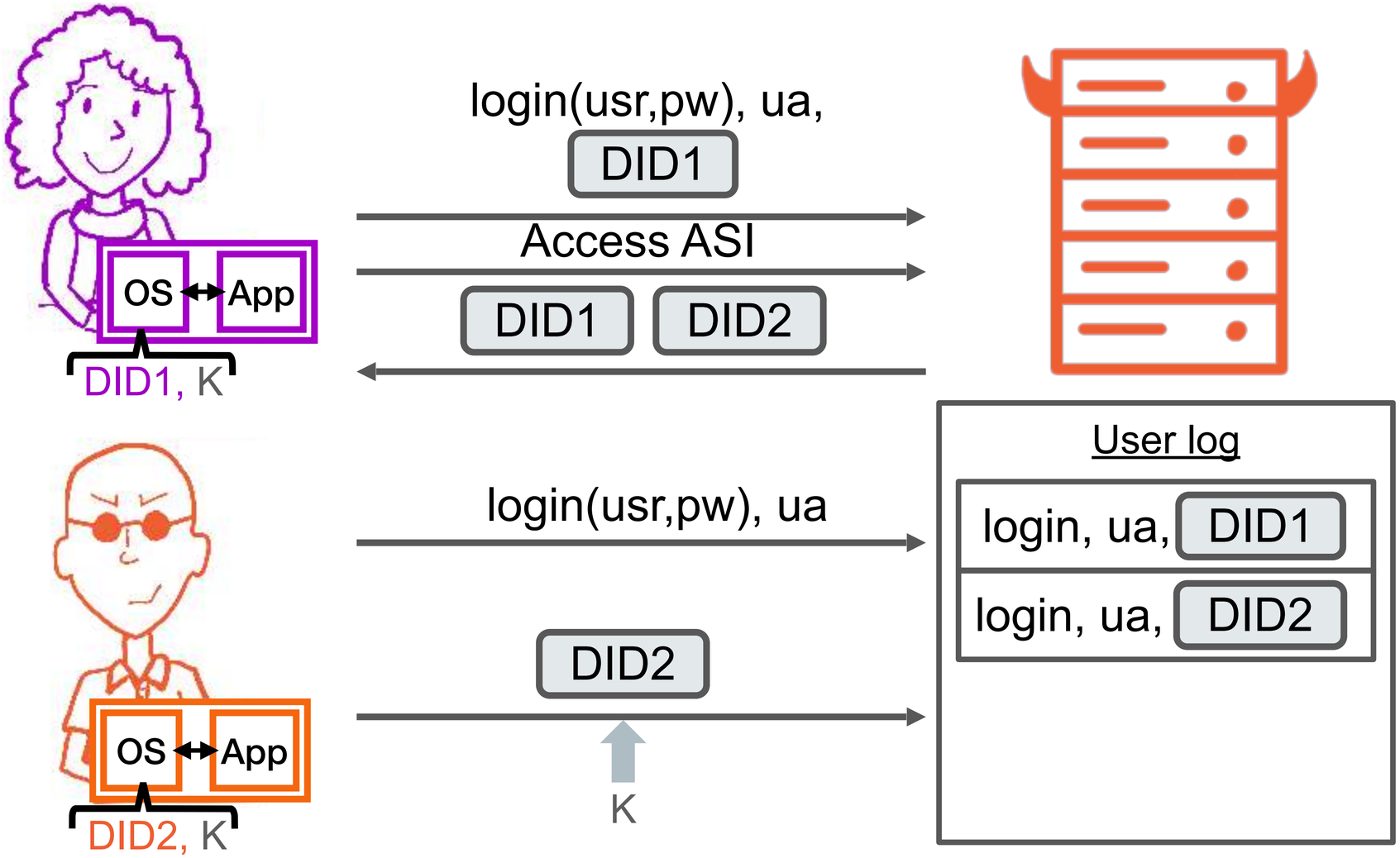
Towards a complete CSAL



Changing the starting assumption



Changing the starting assumption



With synchronized keys we have a complete CSAL without ``Ghost Users”

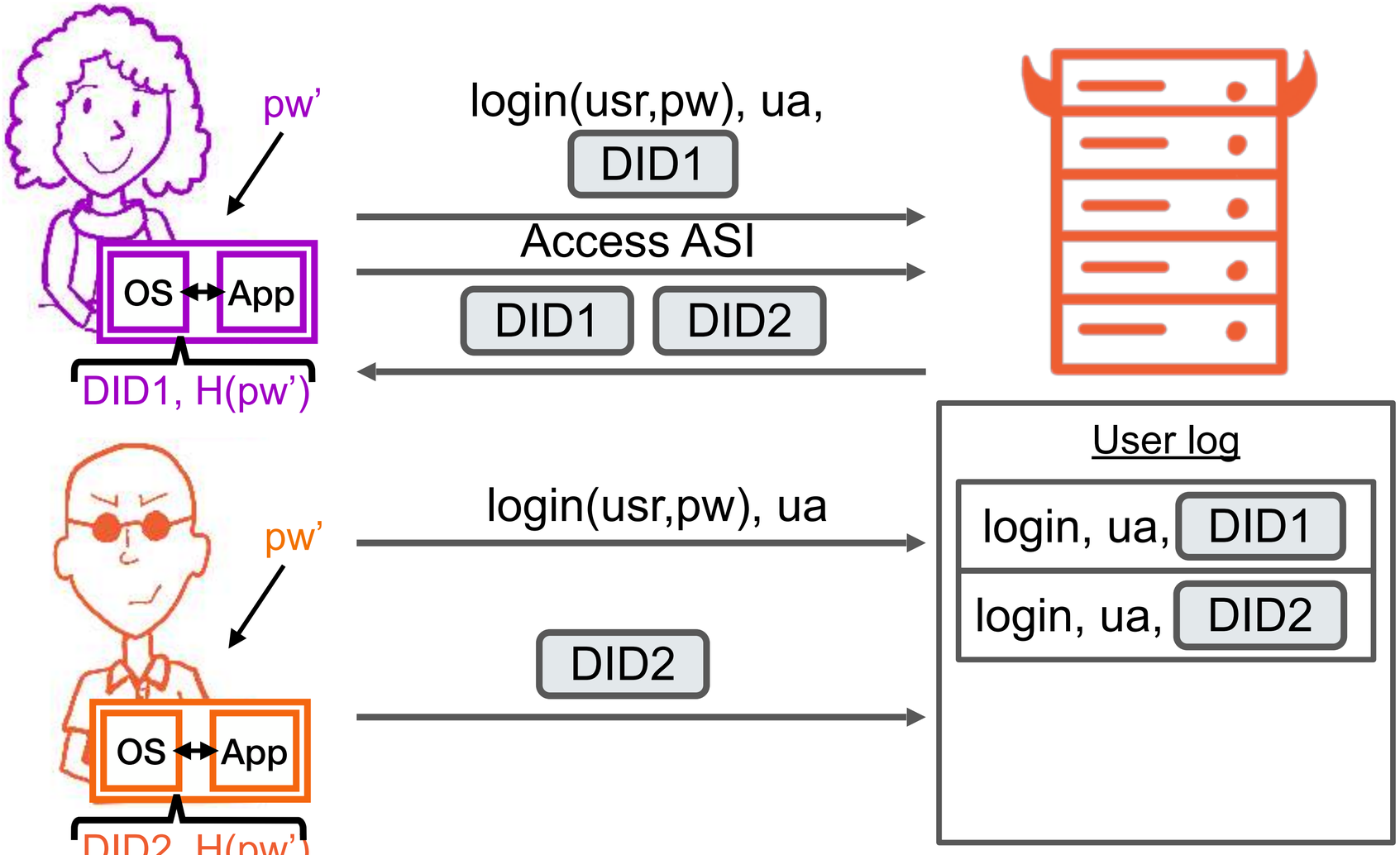
Synchronizing keys across devices

Two possible solutions

- Password-based key synchronization
- Bootstrap passkeys/WebAuthn

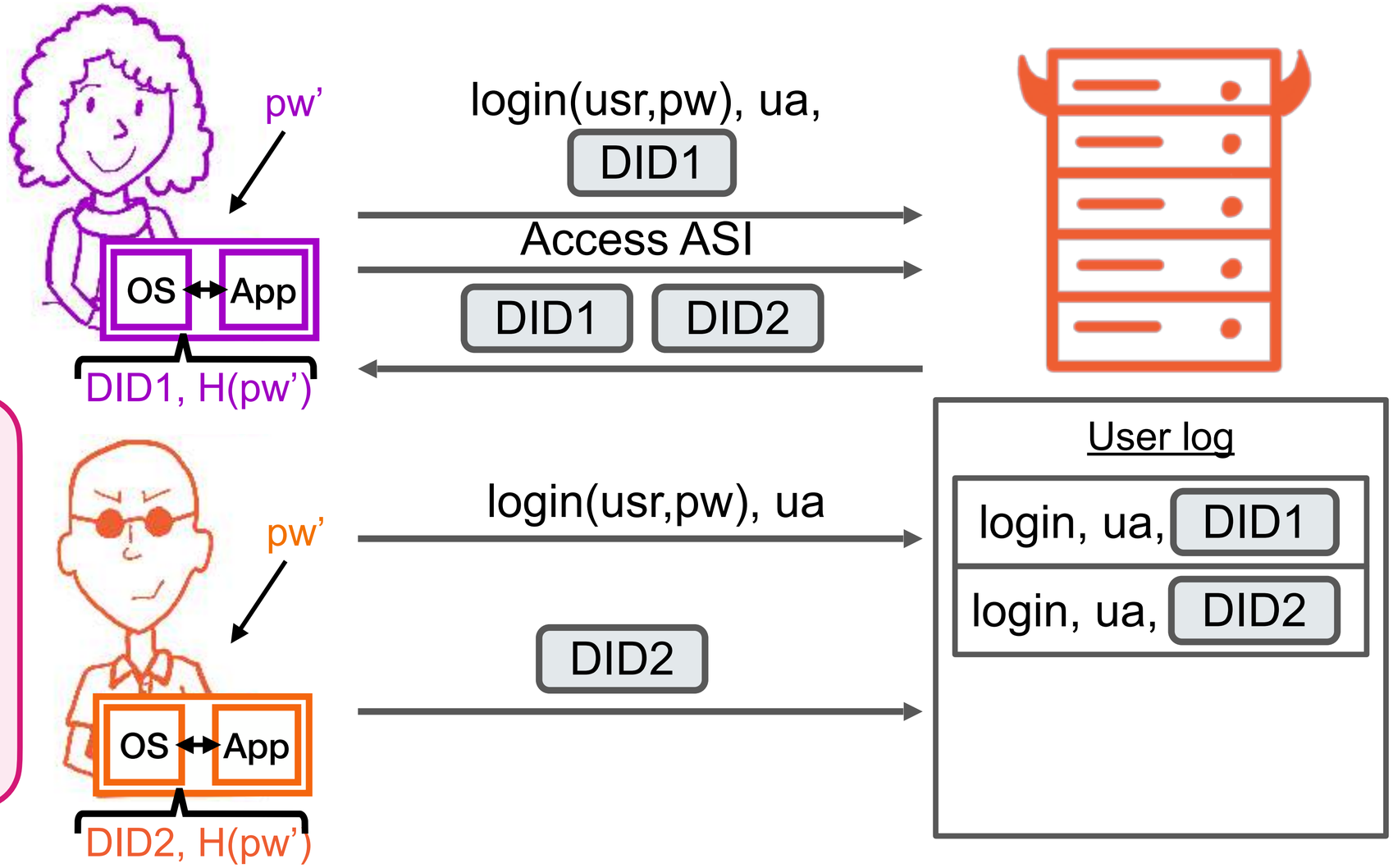
Password-based key synchronization

K = H(pw')



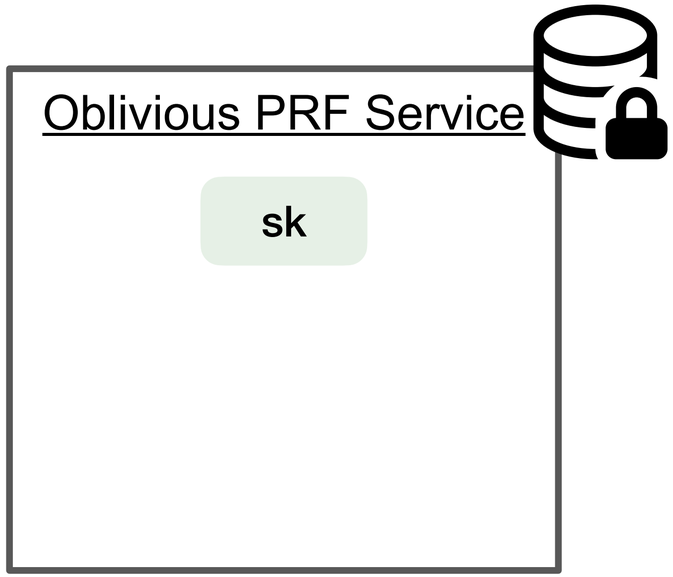
Password-based key synchronization

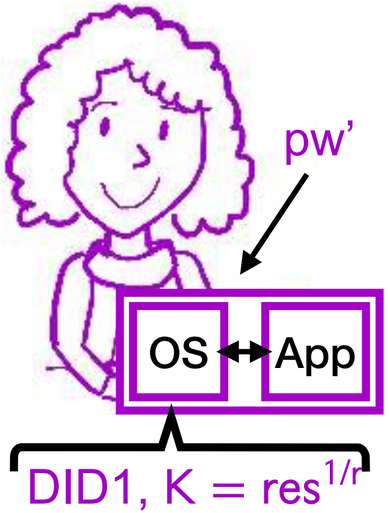
K = H(pw')

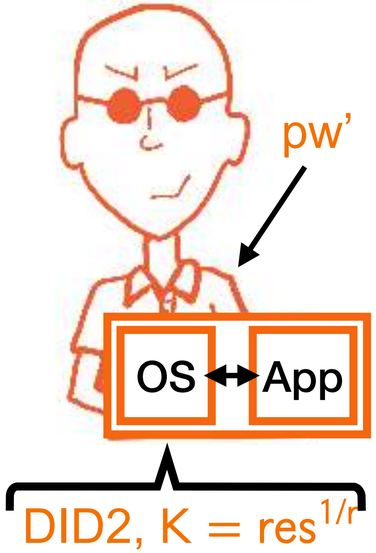


Brute-forceable by malicious servers and malicious users.

Password-based key synchronization



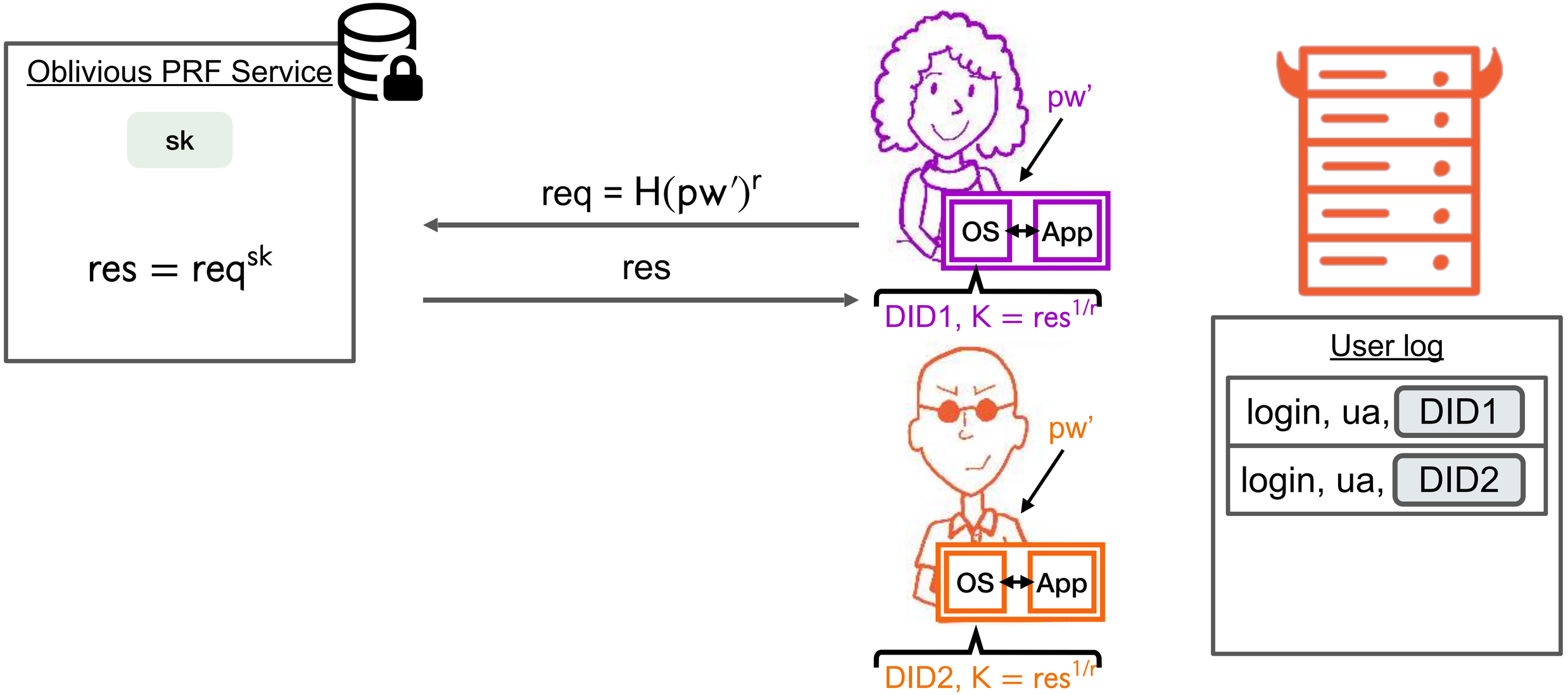




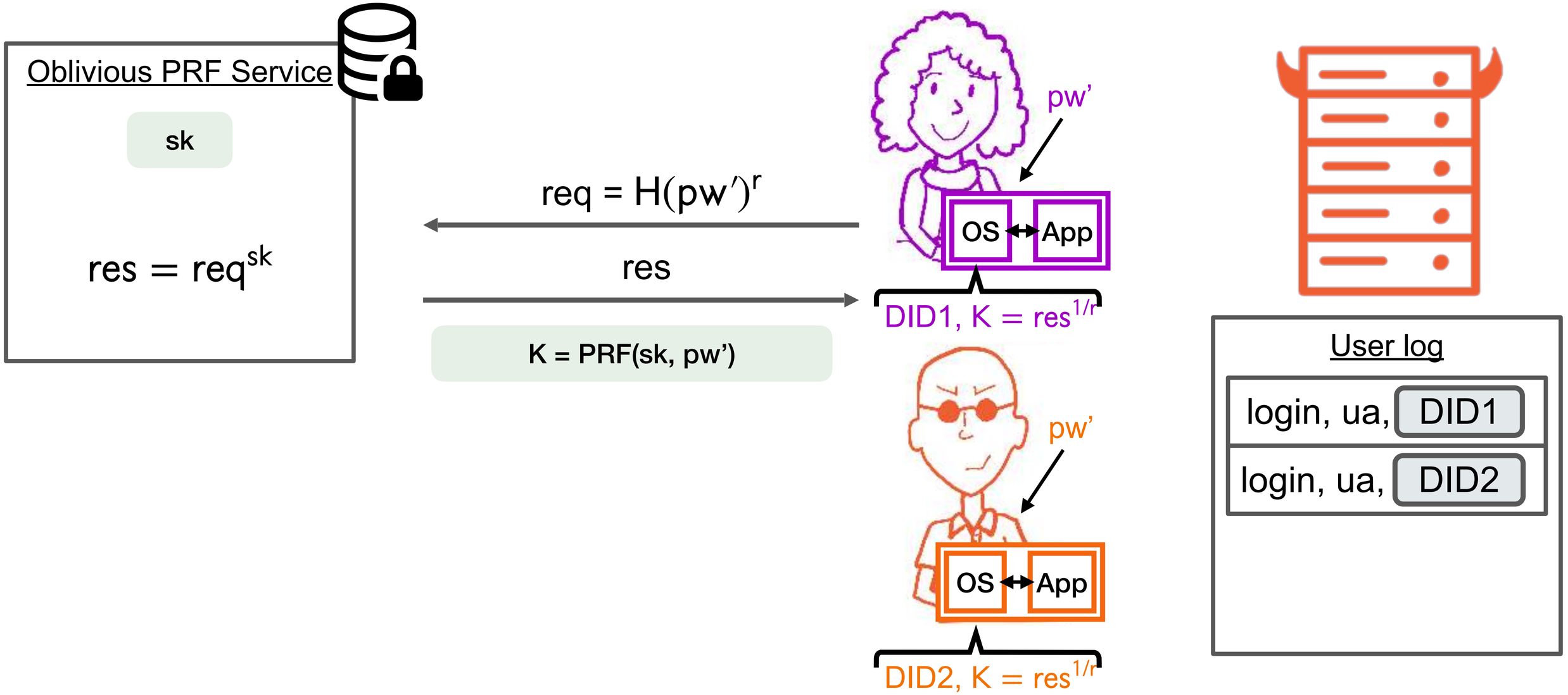
User log

login, ua,	DID1
login, ua,	DID2

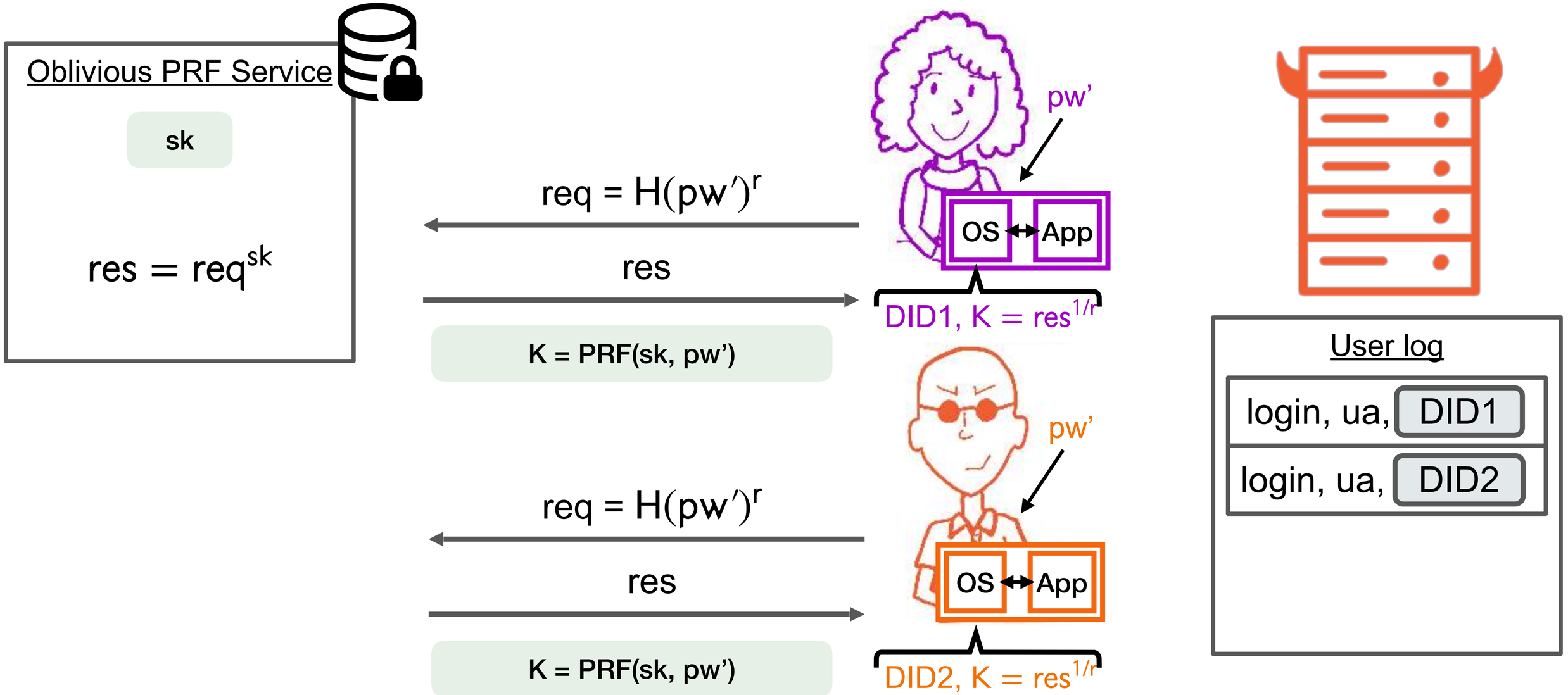
Password-based key synchronization



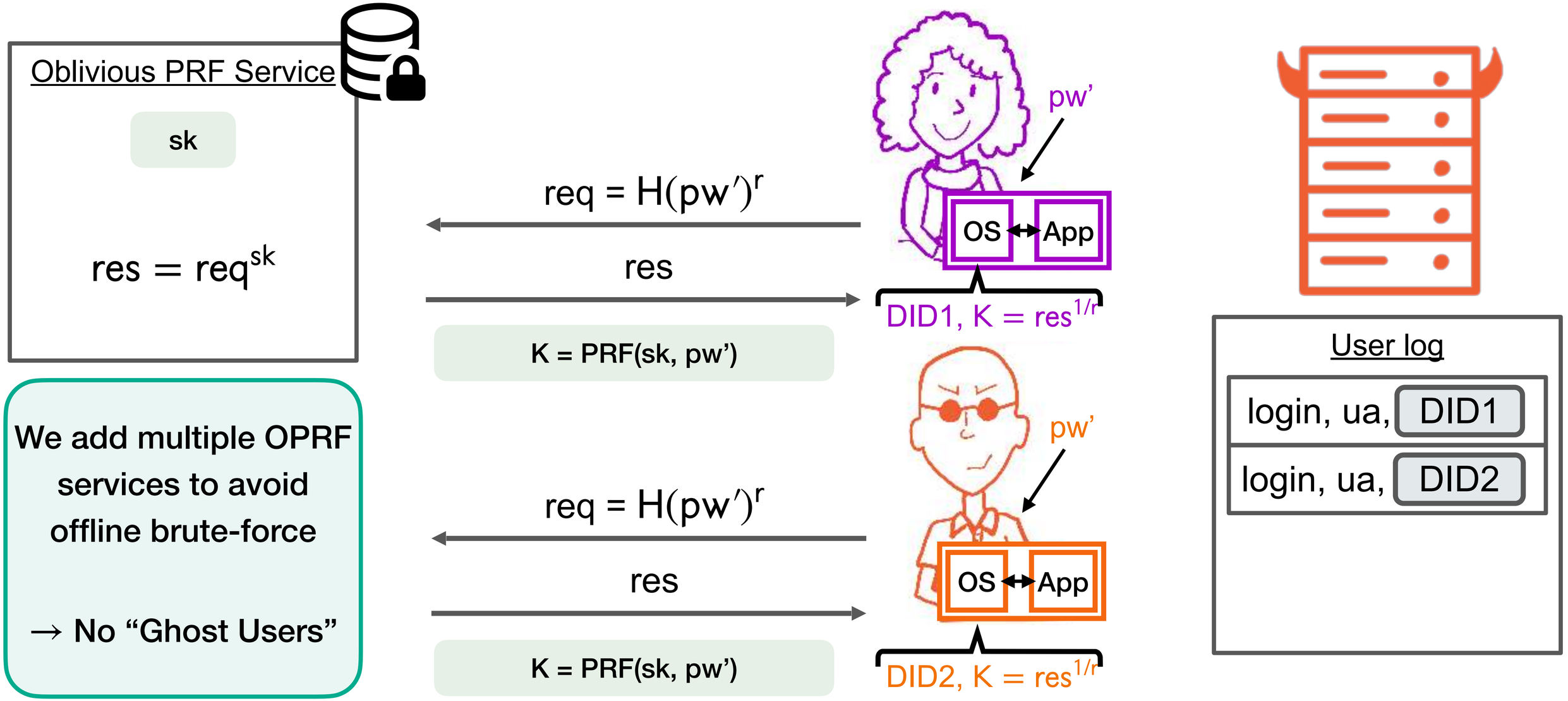
Password-based key synchronization



Password-based key synchronization



Password-based key synchronization

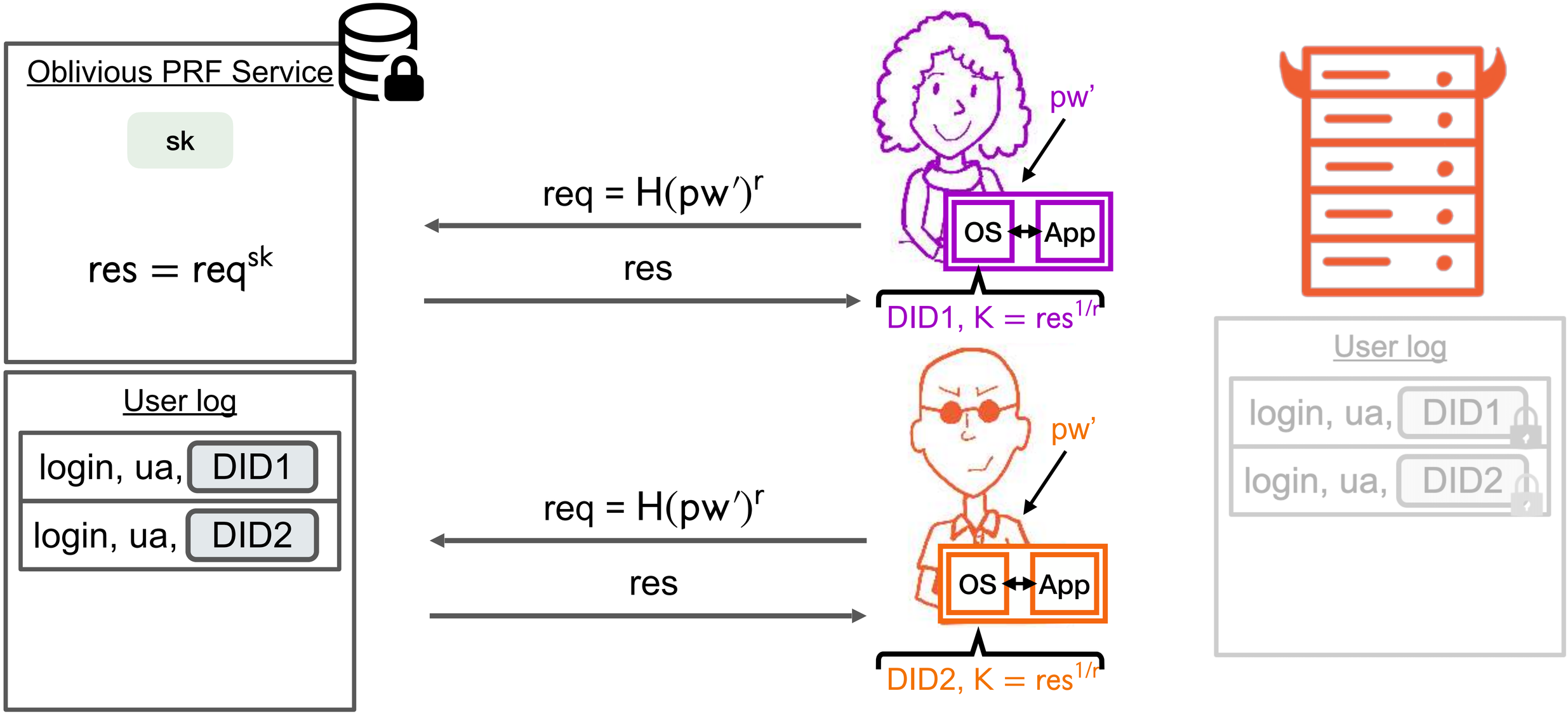


We add multiple OPRF services to avoid offline brute-force

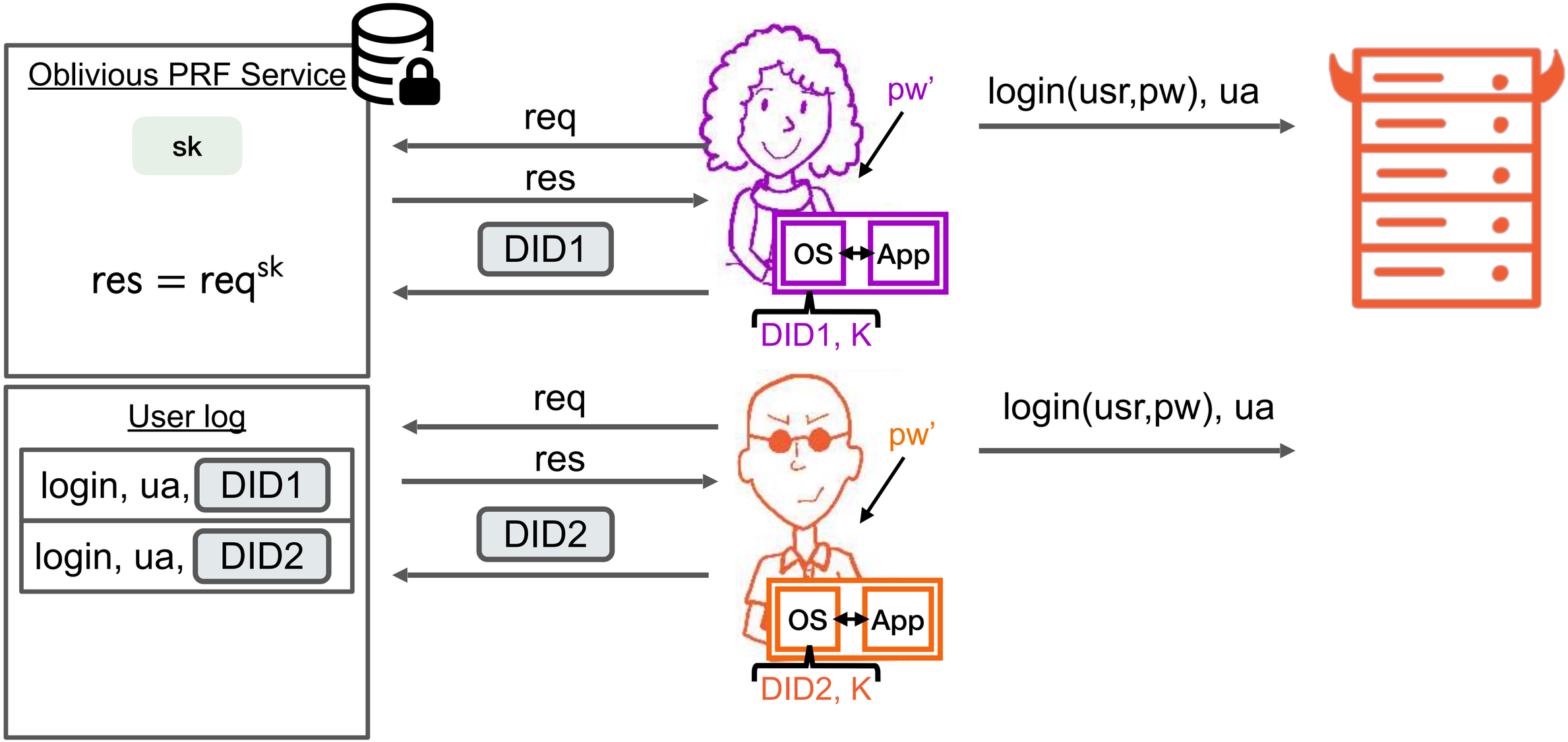
→ No "Ghost Users"

Inspired by highly-efficient and composable password-protected secret sharing; Jarecki et al (2016)

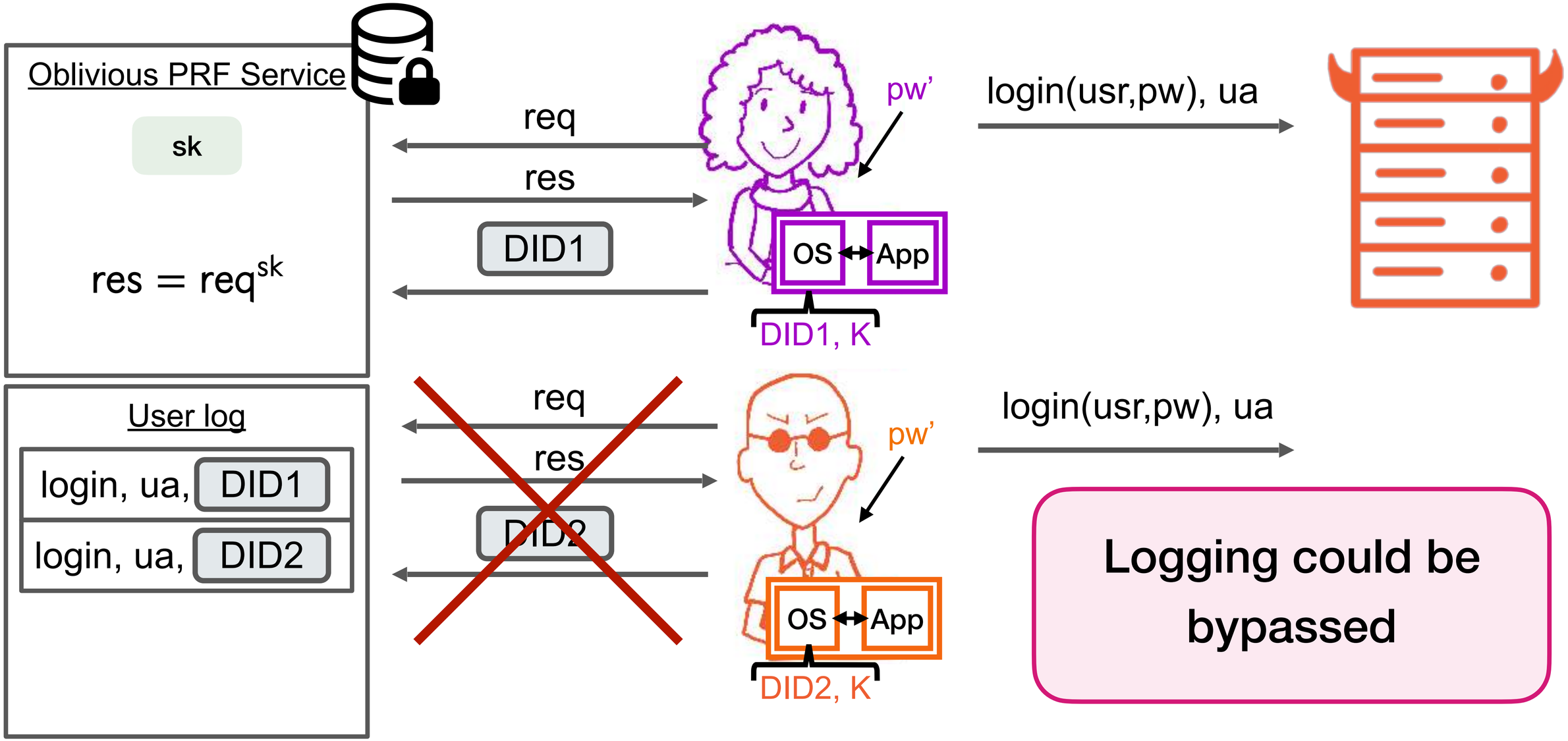
Backwards compatibility



Backwards compatibility

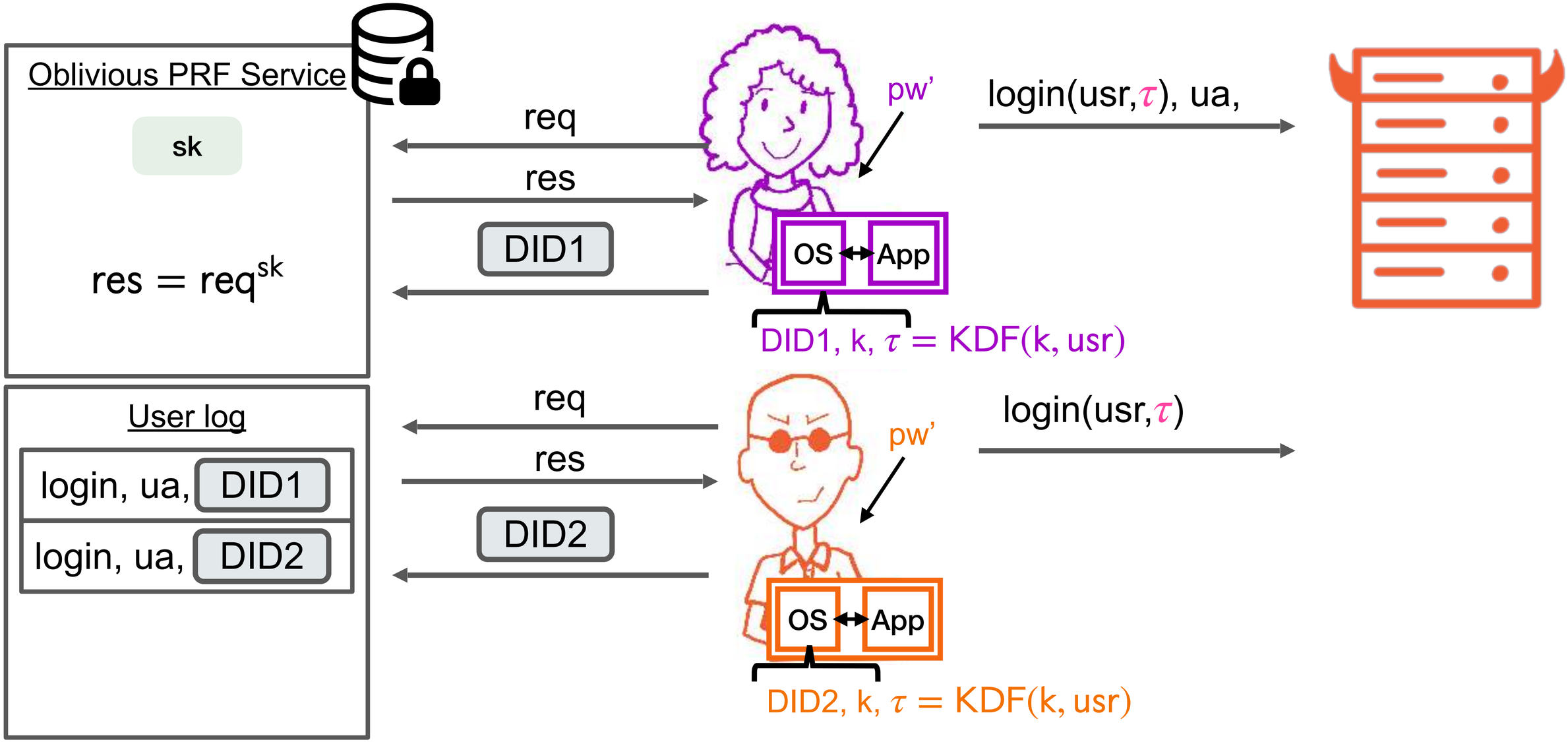


Backwards compatibility



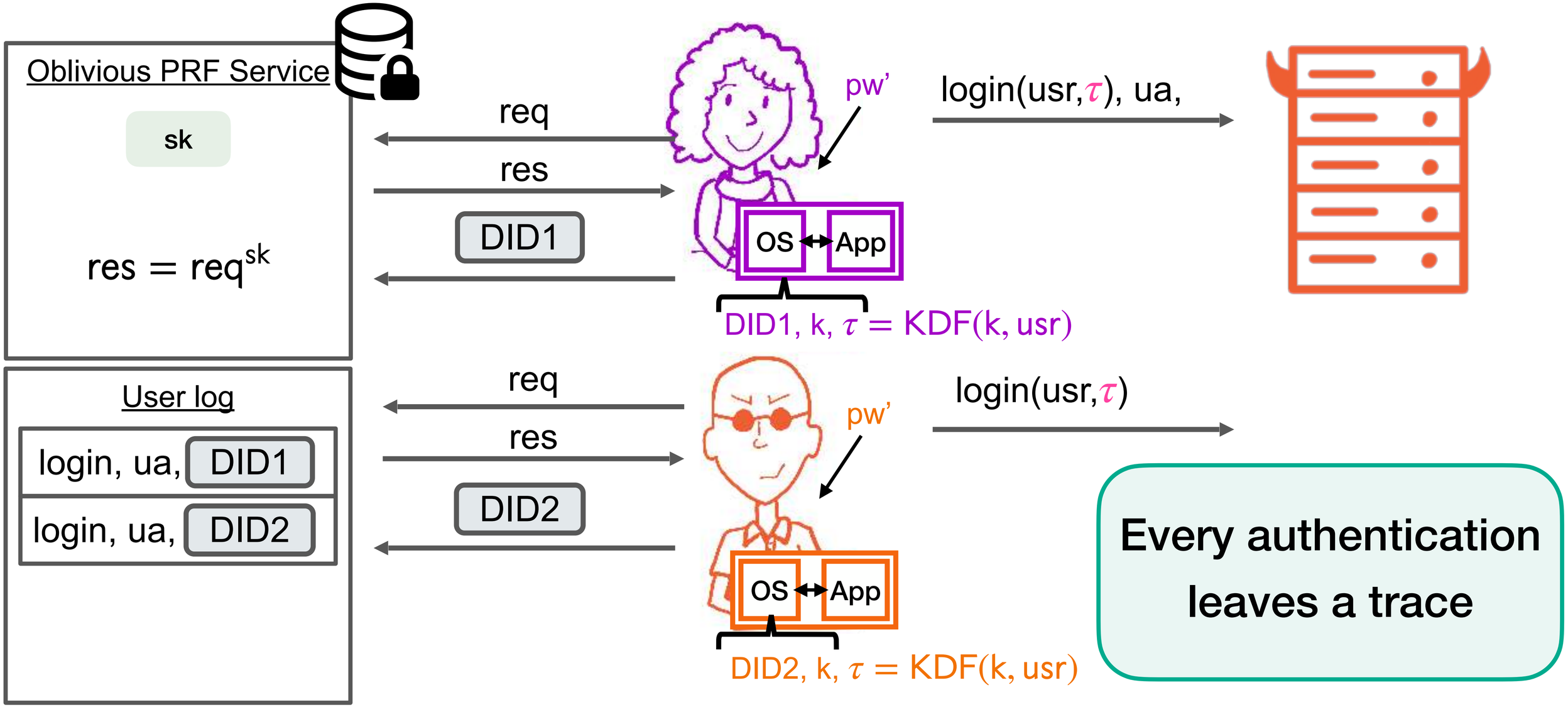
Logging could be bypassed

OS-derived credentials



Inspired by the Larch system for universal login; Dauterman et al (2023)

OS-derived credentials



Every authentication leaves a trace

Inspired by the Larch system for universal login; Dauterman et al (2023)

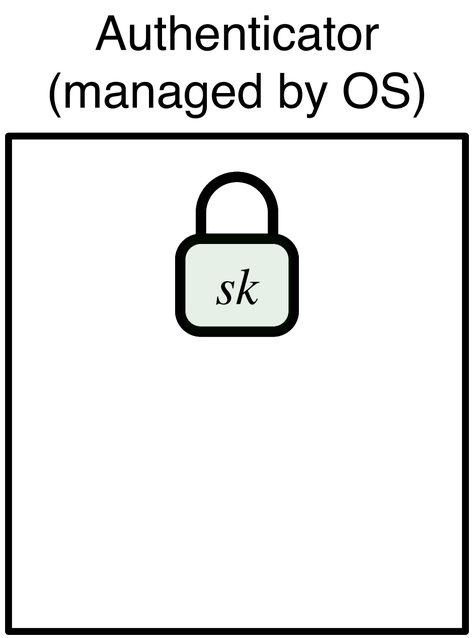
Synchronizing keys across devices

Two possible solutions

- Password-based key synchronization
- Bootstrap passkeys/WebAuthn

WebAuthn

(Simplified) state of the art

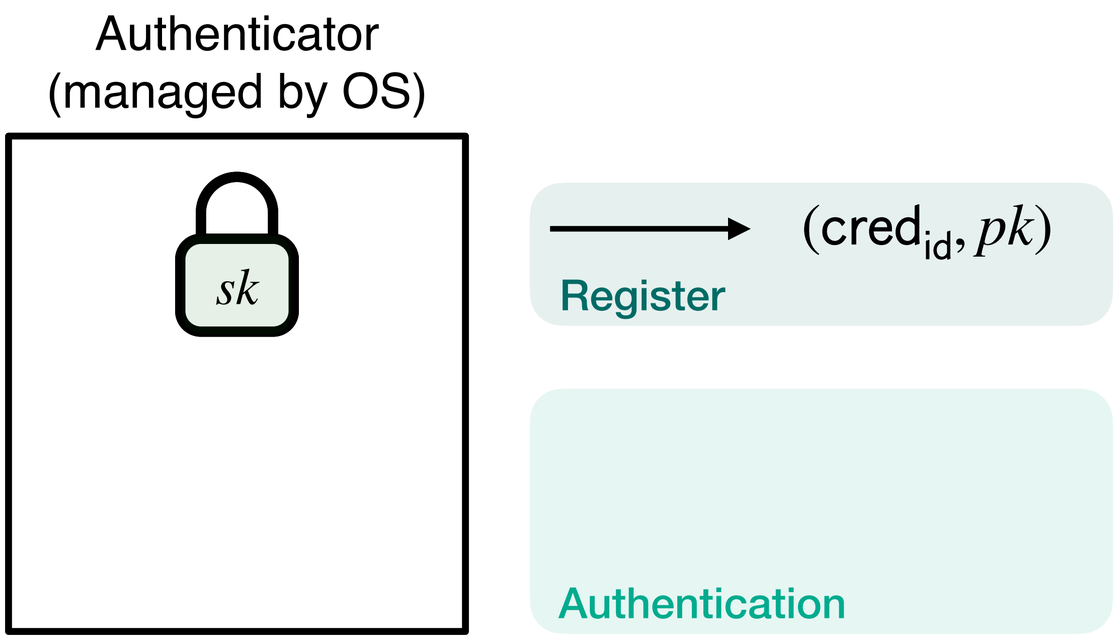


Register

Authentication

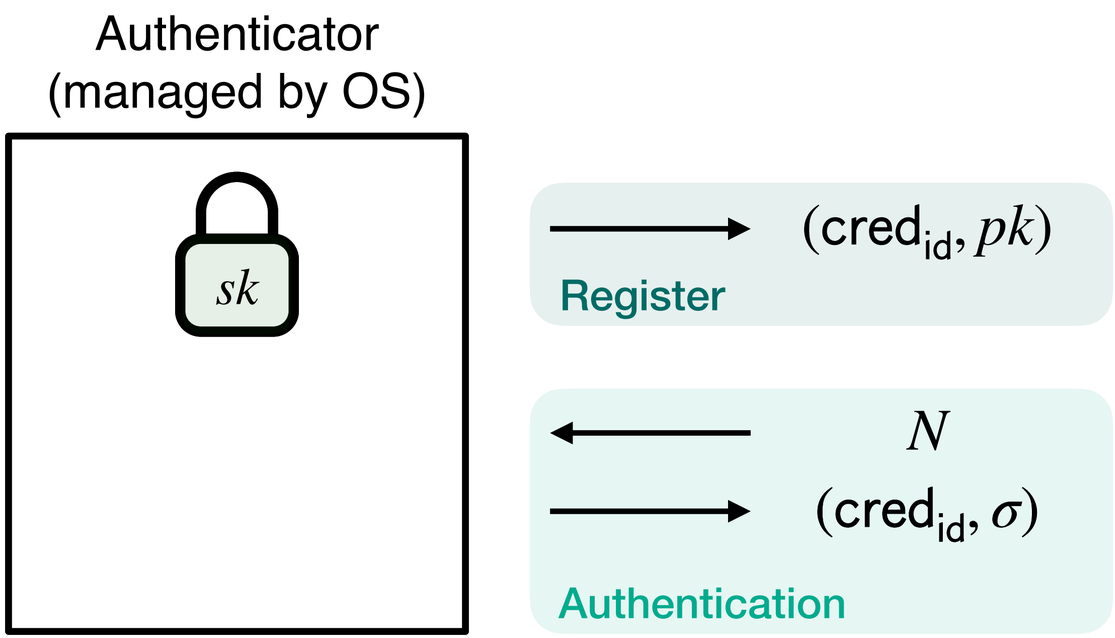
WebAuthn

(Simplified) state of the art



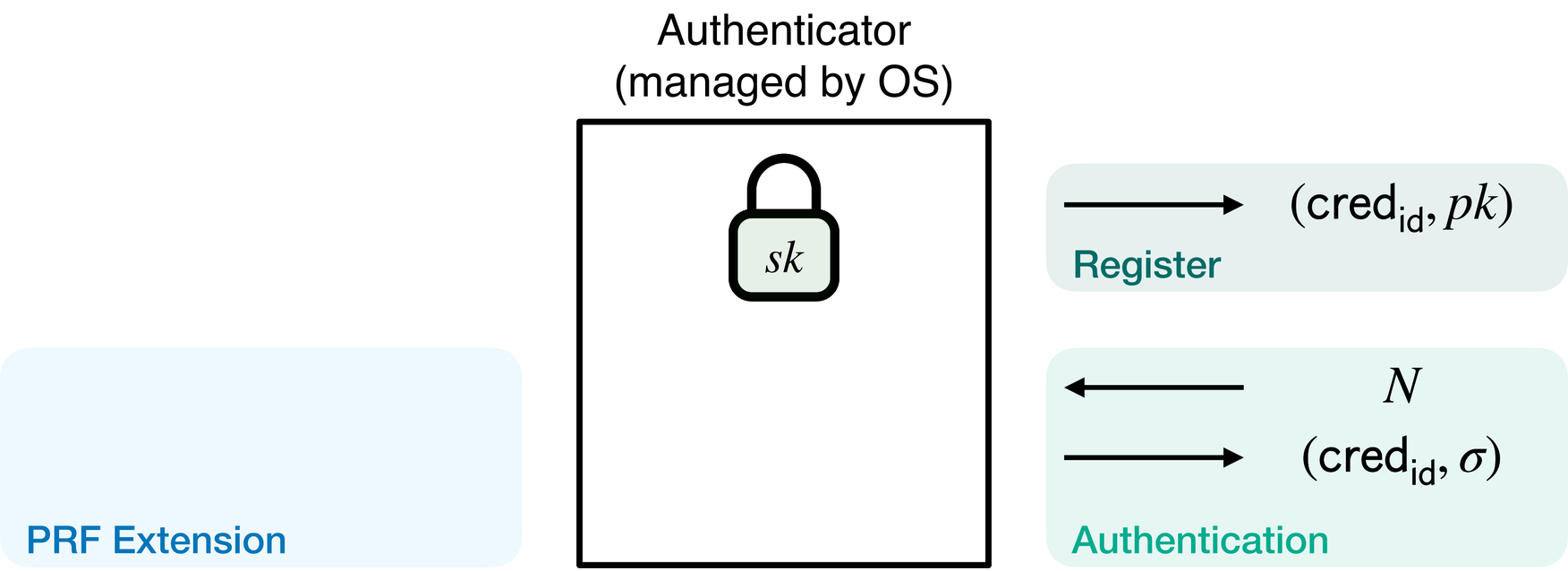
WebAuthn

(Simplified) state of the art



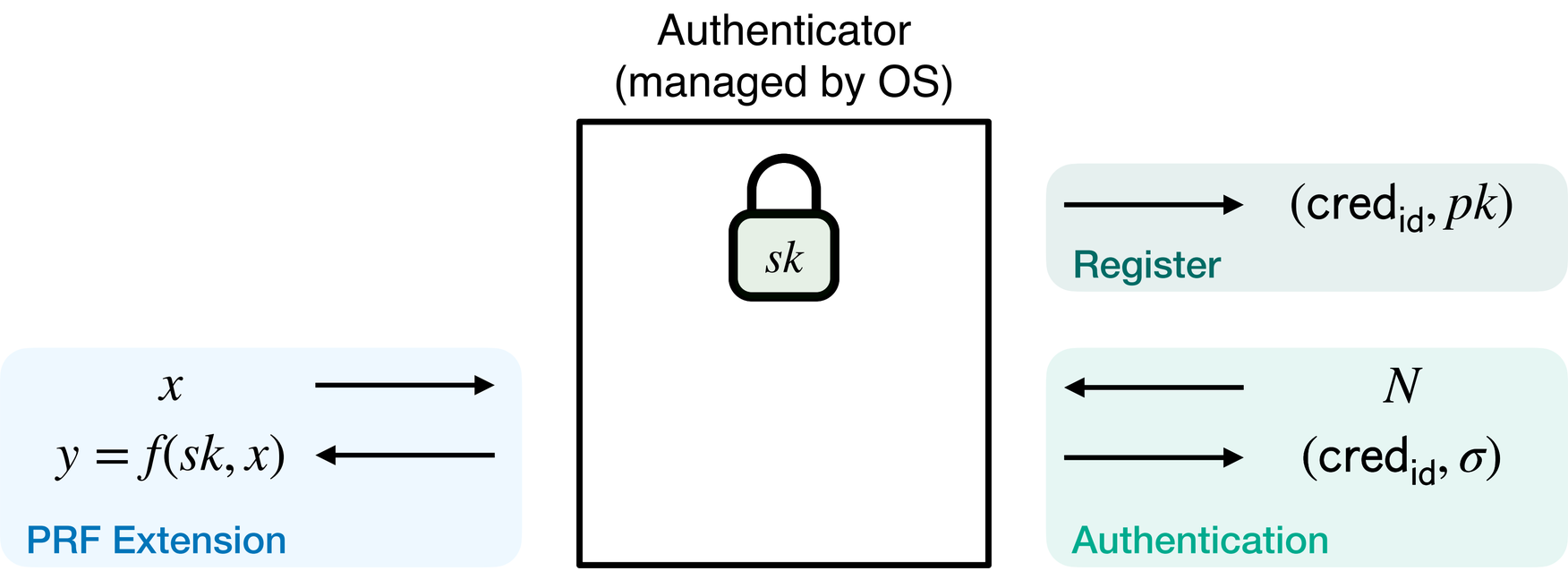
WebAuthn

(Simplified) state of the art



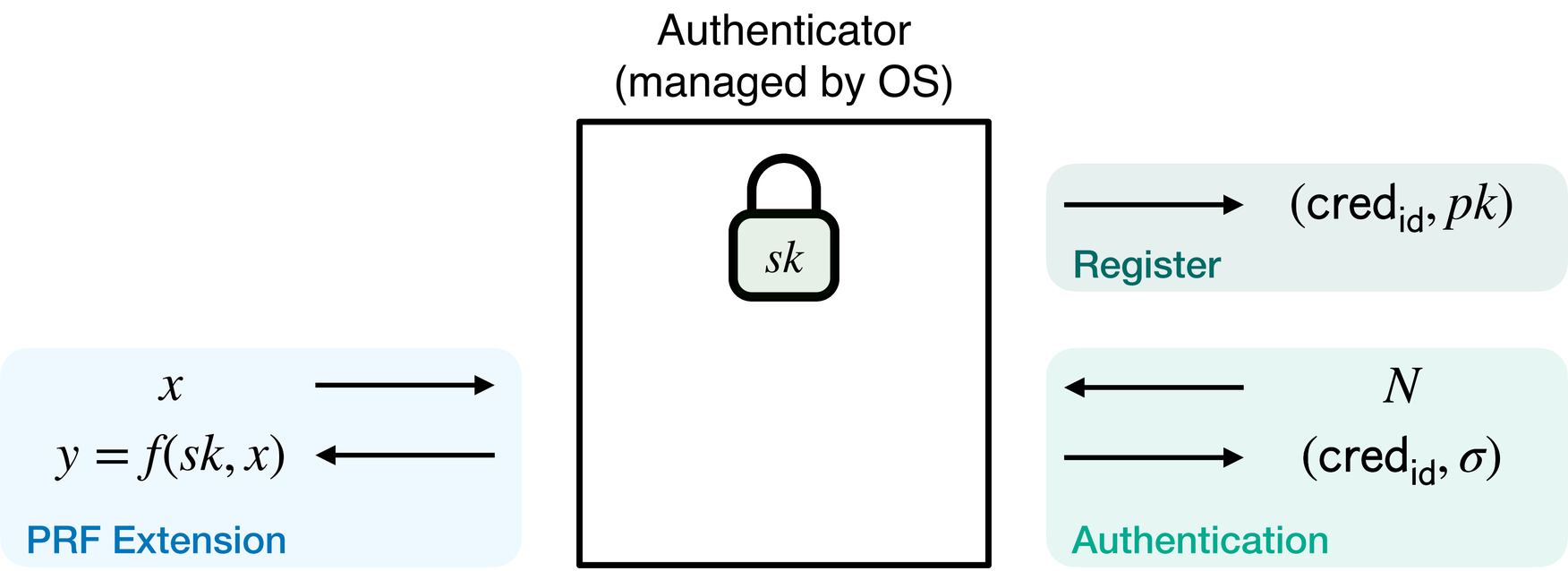
WebAuthn

(Simplified) state of the art



WebAuthn

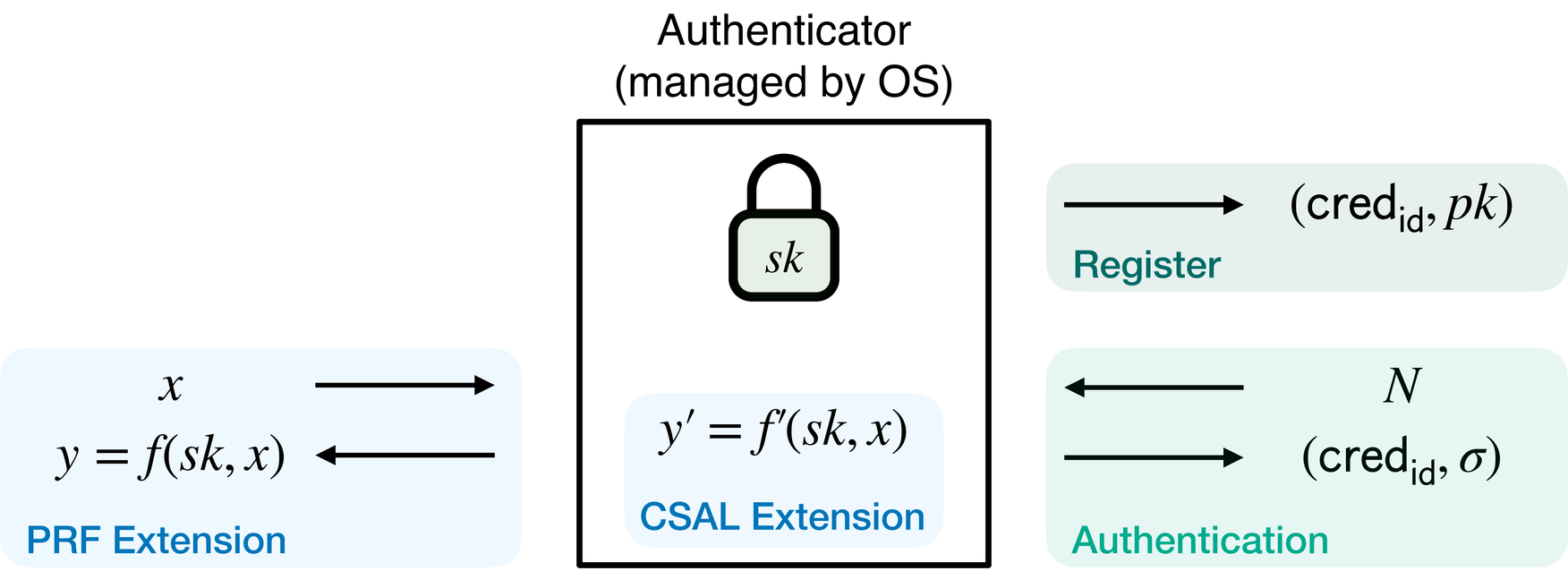
(Simplified) state of the art



Output accessible by the client

WebAuthn

A modest extension



WebAuthn

Proposed Extension

- PRF Extension is computed via
  - $f(sk, inp) =$ SHA-256(''WebAuthn PRF'' $||0x00||inp$)

WebAuthn

Proposed Extension

- PRF Extension is computed via
  - $f(sk, inp) = \text{HMAC}(sk, \text{SHA-256}(\text{''WebAuthn PRF''} \,||\, 0x00 \,||\, inp))$

WebAuthn

Proposed Extension

- PRF Extension is computed via
  - $f(sk, inp) = \text{HMAC}(sk, \text{SHA-256}(\text{''WebAuthn PRF''} \,||\, 0x00 \,||\, inp))$
- CSAL extension could be computed via
  - $f'(sk, inp) = \text{HMAC}(sk, \text{SHA-256}(\text{''CSAL PRF''} \,||\, 0x00 \,||\, inp))$

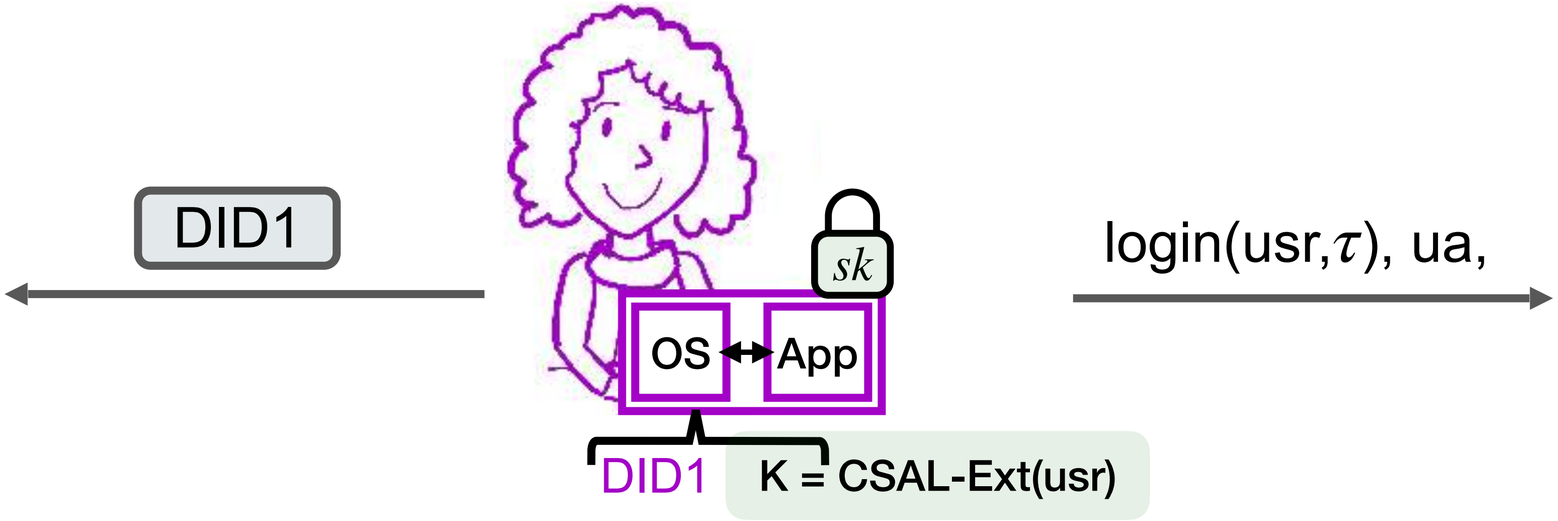
WebAuthn

Proposed Extension

- PRF Extension is computed via
  - $f(sk, inp) = \text{HMAC}(sk, \text{SHA-256}(\text{''WebAuthn PRF''} \,||\, 0x00 \,||\, inp))$
- CSAL extension could be computed via
  - $f'(sk, inp) = \text{HMAC}(sk, \text{SHA-256}(\text{''CSAL PRF''} \,||\, 0x00 \,||\, inp))$
- CSAL PRF output must
  - only be available to the Platform (OS),
  - not be available to the client, or the RP

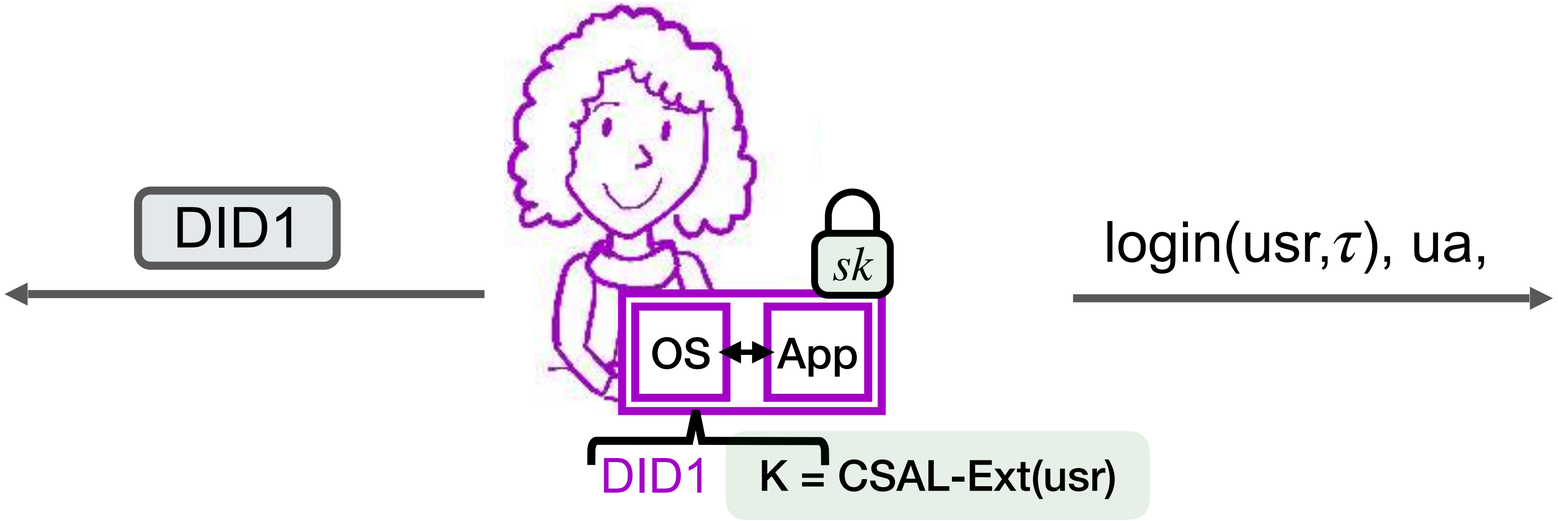
Using the Extension in Trace

OS has access to credential and runs the CSAL extension



Using the Extension in Trace

OS has access to credential and runs the CSAL extension



Privacy ✓

Completeness ✓

PK-CSAL vs Trace: comparison

PK-CSAL	Trace
Unspoofable ASIs	
No persistent state, but can be incomplete	Complete, requires pw or synced key
Privacy against honest-but-curious servers (“Ghost Users”)	Privacy against malicious servers
RPs need to support logging	Backwards compatible

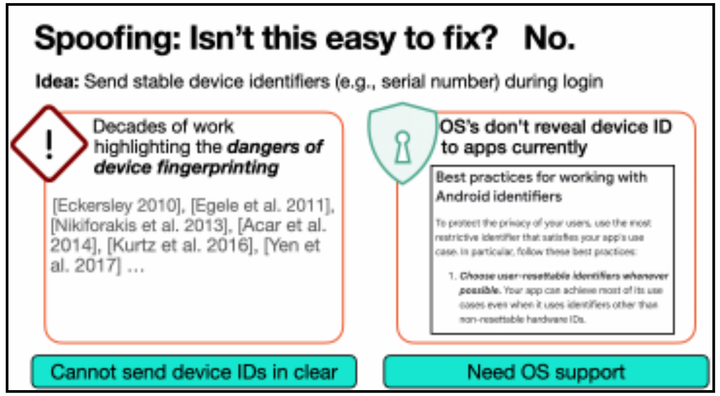
Deployment considerations

Key deployment issue: OS support

Key deployment issue: OS support

OS support will be the lynchpin

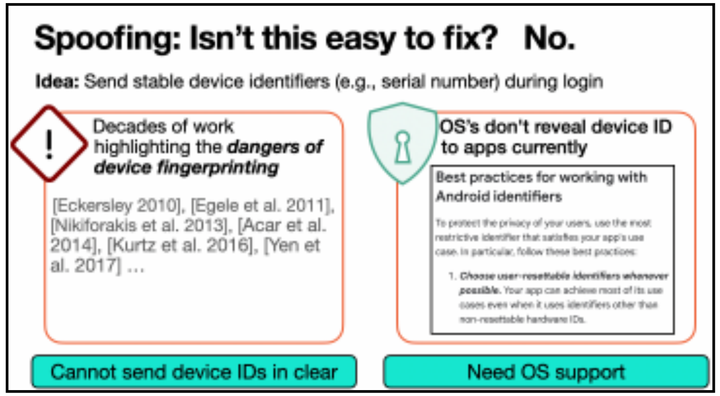
- Fundamental for unspoofable identifiers
- If Apple, Google and Microsoft support CSAL, we cover ~95 % of users worldwide



Key deployment issue: OS support

OS support will be the lynchpin

- Fundamental for unspoofable identifiers
- If Apple, Google and Microsoft support CSAL, we cover ~95 % of users worldwide

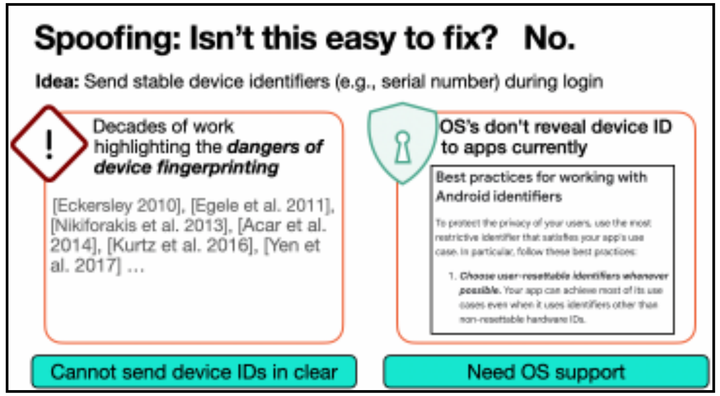


Everything except OS support will require extensive **engineering** but is **conceptually straightforward** with our protocols + existing web technologies

Key deployment issue: OS support

OS support will be the lynchpin

- Fundamental for unspoofable identifiers
- If Apple, Google and Microsoft support CSAL, we cover ~95 % of users worldwide



Everything except OS support will require extensive **engineering** but is **conceptually straightforward** with our protocols + existing web technologies

Proof of concept: Performance is not an issue

Improving Account Security for Victims of Account Compromise through Client-Side Access Logging

1. ASIs are important but do not have integrity
2. CSAL enables reliable ASIs
3. OS vendors collaboration is crucial to deploy CSAL

Let's discuss our WebAuthn extension proposal!

Carolina Ortega Pérez
carolina@cs.cornell.edu

Paul Gerhart
mail@paul-gerhart.de

Alaa Daffalla
alaadaffalla@cs.cornell.edu

Thomas Ristenpart
ristenpart@cornell.edu

PK-CSAL:
bit.ly/452AiTa

Trace:
eprint.iacr.org/2026/447